OCI Zero Trust Architecture – Multi-Perimeter Model and Intent-Based Access Control

Author: Alessandro Moccia
Oracle ACE / Accenture

Document Objectives

Introduction and Scope of the Zero Trust Security Model on OCI

The objective of this document is to define a Zero Trust Security architectural model on Oracle Cloud Infrastructure (OCI) that goes beyond a point-by-point description of individual security controls, and instead frames the entire OCI ecosystem as a system of multiple, dynamic, and intent-based security perimeters.
In this model, OCI security services are not treated as isolated safeguards, but as coordinated components of a multilayer architecture, where each control operates on a specific plane (identity, access, configuration, network, runtime, audit) and contributes to the overall reduction of risk.

A central objective of this document is to clarify how Zero Trust Packet Routing (ZPR) represents a paradigm shift in the way traffic security is implemented within the cloud. ZPR does not introduce a new static perimeter; instead, it enables an intent-based enforcement model in which security boundaries are defined by the identity and role of resources rather than by their topological placement. This paradigm allows multiple perimeters to be governed consistently and simultaneously, covering both east–west flows within the Data Plane and north–south flows toward services and external access points. The approach aligns naturally with modern cybersecurity principles that require the elimination of implicit trust, dynamic segmentation, and the reduction of

lateral movement, and it is consistent with internationally adopted Zero Trust frameworks and guidelines.

The document further aims to systematically analyze the OCI security services and tools catalog, clearly distinguishing their application across the Control Plane and the Data Plane. On the Control Plane, the focus is on identity, authentication, authorization, governance, and API protection. On the Data Plane, security concerns the communication between resources, traffic segmentation, workload protection, and the limitation of lateral movement. Services and controls such as IAM, Network Perimeters, Deny Policies, Security Zones, Cloud Guard, Network Security Groups (NSGs), Network Firewall, Web Application Firewall (WAF), and ZPR are therefore positioned within the appropriate Zero Trust layer, explicitly outlining for each its scope of enforcement, the problems it addresses, its inherent limitations, and its dependencies on other controls.

Finally, this document intends to provide practical criteria, usage scenarios, and best practices for adopting OCI security controls, clarifying how to combine them correctly based on architectural context, risk level, and compliance requirements. The goal is not to define a single configuration applicable to all cases, but to offer an architectural interpretation that enables the design of coherent, verifiable, and adaptable solutions, avoiding fragmented or purely descriptive approaches while maintaining a unified security vision across the entire platform.

Summary

- Frame OCI as a multi-layer, multi-perimeter Zero Trust architecture
- Analyze the OCI security tools catalog from an architectural perspective
- Clearly distinguish between Control Plane and Data Plane
- Highlight ZPR as an intent-based paradigm for both east–west and north–south traffic
- Map each security control to the appropriate Zero Trust layer, defining roles and limitations
- Provide scenarios and best practices for reducing blast radius and lateral movement

OCI Zero Trust Security: Architectural Model

OCI Security Architecture: Adoption of the Zero Trust Model

"This document describes a reference Zero Trust Architecture on Oracle Cloud Infrastructure, based on official Oracle documentation and industry standards (NIST SP 800-207, CISA ZTMM). It does not represent an Oracle product roadmap and does not replace official Oracle documentation."

- **Security Foundations in OCI**
  Oracle Cloud Infrastructure security is defined, in official documentation, as a set of distinct control domains operating across different surfaces of the platform, specifically the **Control Plane** and the **Data Plane**, within a shared responsibility model.
  As described in the OCI Security Overview, these domains include identity and access management, network security, workload protection, misconfiguration prevention, logging, and monitoring. Oracle does not introduce a single perimeter acting as a centralized

enforcement point; instead, it adopts a **distributed approach**, where different controls address different risks and operate at specific points within the architecture.

- **Alignment with the Zero Trust Paradigm**
  In the *Zero Trust Security on Oracle Cloud Infrastructure* white paper, Oracle explicitly states the adoption of the Zero Trust paradigm, aligning with the principles defined in **NIST SP 800-207**. In this model, there is no implicit trust based on network location, topology, or resource placement. Each access request is evaluated based on identity, context, and policy, and enforcement must be continuous and consistent throughout the entire resource lifecycle. Oracle emphasizes that, in cloud environments, security must protect **resources, services, and workloads**, rather than static network segments.

OCI Security Architecture: Adoption of the Zero Trust Model

- ### Multi-Perimeter Architecture

- The Oracle Cloud Infrastructure (OCI) security model must be interpreted as an architecture composed of **distinct control domains applied across different surfaces**, with a **clear structural separation between the Control Plane and the Data Plane**, as described in the official OCI *Security Overview* documentation.
  In this model, there is no single perimeter that is valid for all risks. Identity, authorization, preventive guardrails, network enforcement, and observability operate on different planes and must be composed coherently to achieve a **verifiable, enterprise-grade security model**.

- ### Technical Introduction: Multi-Perimeter Architecture with Distributed Enforcement

- Zero Trust Security, as formalized by **NIST SP 800-207** and operationalized through maturity models such as **CISA ZTMM**, does not define a prescriptive stack of security layers. Instead, it requires the explicit identification of **decision points** and **enforcement points** governing access to resources and communication between them.
  In a public cloud environment, this requirement implies abandoning topology-based perimeters in favor of a **multi-perimeter architecture**, where distinct perimeters operate across different functional domains (governance, administrative access, application traffic) and across different traffic types (**north–south** and **east–west**), with controls that are verifiable **before execution**, **during execution**, and **after execution**.
- In Oracle Cloud Infrastructure, the Zero Trust architecture emerges from the coherent integration of native controls, each positioned exclusively at the point where it can exercise **real authority**. The structural separation between the **management plane** and the **execution plane** is foundational.
  The management plane includes consoles and application programming interfaces and is **public by design**; therefore, its security perimeter must be **identity-centric and context-aware**, rather than network-based. In this domain, enforcement is implemented through authorization policies with **deny precedence** and contextual constraints that qualify a request **before any operation is executed**.
  Controls such as **IAM Deny Policies**, **Network Sources**, and **Network Perimeters** (at the Identity Domain level) define an **administrative north–south perimeter**, in which even a valid identity is rejected if the context is non-compliant. This perimeter is **ex-ante**: it acts

before any effect occurs and is the only perimeter model consistent with the public nature of the Control Plane.

OCI Security Architecture: Adoption of the Zero Trust Model

Preventive governance represents a distinct perimeter that cannot be reduced to either traffic control or API access. **Landing Zones** and **Security Zones** define security domains in which operations are validated against an approved posture **before** they are accepted. In this domain, enforcement does not filter packets or requests; instead, it constrains the space of allowable configurations, reducing systemic risk and imposing **non-bypassable controls**. **Cloud Guard** completes this perimeter by providing continuous detection of deviations and response capabilities, closing the governance loop through observability and accountability. This domain satisfies organizational control and accountability requirements referenced by regulatory frameworks (including European ones), as it operates as a **structural ex-ante guardrail** and **ex-post evidence** mechanism.

Within the **execution plane**, the dominant architectural concern is **lateral movement**. **East–west traffic** between workloads—typically within the same virtual network or across interconnected networks—is the primary propagation vector. Traditional segmentation controls (**Security Lists** and **Network Security Groups**) provide necessary but insufficient topological isolation, as they depend on the correctness of the IP design. OCI therefore introduces a **runtime enforcement perimeter** based on **intent and resource identity** through **Zero Trust Packet Routing (ZPR)**, which applies per-request decisions at the network level, independently of topology. This perimeter governs both **east–west** and **application north–south** flows within the Data Plane and is designed to be robust against network misconfigurations.

Edge and deep inspection controls (such as **Web Application Firewall** and **Network Firewall**) do not define the Zero Trust model but complement it where required—providing Layer-7 protection, inspection, and mitigation of specific threats. These controls are **placement-driven** and operate on well-defined perimeters, without replacing the **intent-based runtime enforcement**. Finally, **auditability** (management plane audit logs and execution plane flow logs) provides the necessary **ex-post perimeter** for attribution, response, and continuous improvement, making the architecture defensible from both a technical and regulatory standpoint.

In summary, referring to "layers" is meaningful only as a functional abstraction. In OCI, Zero Trust Security is a **composition of overlapping perimeters**, each with distinct authority, timing, and technical effect. The architecture is correct not because it enumerates controls, but because it places each control at the point where it can **effectively deny, allow, or constrain**.

OCI Security Architecture: Adoption of the Zero Trust Model

Zero Trust Security in OCI is formalized as a system of **distributed policy decision and enforcement**, rather than as a set of isolated controls or a rigid stack of numbered layers. Consistent with the **NIST Zero Trust Architecture (SP 800-207)**, OCI implements an explicit separation between **policy decision points** and **policy enforcement points**, allocated across different domains of the cloud architecture.

Within the **management plane**, which is **public by design**, access decisions are governed by **identity, context, and deny-precedence policies**, while enforcement occurs **before the execution** of the operation, preventing non-compliant requests from producing any effect. In parallel, OCI introduces a layer of **preventive governance** that operates **ex-ante with respect to access**, constraining the space of admissible configurations through structural validation of operations, thereby reducing systemic risk independently of actor behavior.

Within the **execution plane**, Zero Trust Architecture manifests as **runtime enforcement of communication flows**, with particular emphasis on **east–west traffic between resources**, which Oracle documentation identifies as the primary attack propagation vector. In this domain, **Zero Trust Packet Routing (ZPR)** must not be interpreted as a traditional network control, but as a **policy enforcement fabric**, capable of applying **intent-based, per-request decisions**, independently of IP topology and resilient to network misconfigurations.

Together, these mechanisms realize a **multi-perimeter architecture**, in which perimeters do not coincide with the network edge, but with the point at which a decision can be **technically enforced**: before execution, during control plane access, and during communication within the data plane. This approach is consistent with **Zero Trust maturity models (CISA)** and with modern regulatory frameworks—including European ones—addressing requirements for control, accountability, and systemic prevention, without introducing artificial taxonomies or controls unsupported by the platform.

OCI Security Architecture: adoption of the Zero Trust model

Architectural summary:

• Zero Trust in OCI is an enforcement architecture, not a list of controls.

• Oracle documentation implicitly describes a Policy Decision Point / Policy Enforcement Point model, which must be made explicit in a technical document.

• Security perimeters are multiple and functional, not topological:
  * preventive governance (ex-ante),
  * access to the management plane (north–south),
  * communication within the execution plane (east–west and north–south).

• Zero Trust Packet Routing is the runtime enforcement mechanism of the data plane, not a firewall nor a traditional segmentation technique.

• Security Zones, Landing Zones, and Deny Policies implement pre-emptive Zero Trust, making certain risk conditions non-configurable.

• The OCI architecture is aligned with NIST SP 800-207 and CISA maturity models without introducing numbered layers or arbitrary taxonomies.

OCI Security Architecture: adoption of the Zero Trust model

Formalization of Policy Decision Point (PDP) and Policy Enforcement Point (PEP) in Oracle Cloud Infrastructure:

• In Zero Trust Architecture, as formalized by NIST in Special Publication 800-207 and adopted as a conceptual reference in Oracle Zero Trust Security documentation, the distinction between Policy Decision Point (PDP) and Policy Enforcement Point (PEP) represents a foundational architectural principle. The Policy Decision Point is the set of mechanisms responsible for evaluating security rules, while the Policy Enforcement Point is the component that makes such decisions effective by allowing or denying the requested action. The separation is not merely logical: a policy is meaningful only if a non-bypassable technical enforcement point exists.

• In Oracle Cloud Infrastructure, this separation is not centralized but distributed by functional domain, consistently with a public cloud architecture characterized by differentiated attack surfaces. In the management plane (control plane), the PDP is implemented by Identity and Access Management services and Identity Domains, which evaluate identity, authentication method, and authorization policies. In this domain, IAM Allow Policies define the permitted scope of action, while IAM Deny Policies—introduced to provide a non-bypassable interdiction mechanism—represent the final decision with absolute precedence. Network Sources operate as authorization conditions evaluated within IAM policies, qualifying requests toward OCI management APIs, which are always authenticated through cryptographic request signing (OCI Signature Version 1). The corresponding Policy Enforcement Point is represented by the control plane APIs, which deterministically apply the PDP decision before any infrastructural operation is executed.

• A distinct domain is represented by application sign-on, which does not coincide with access to management APIs. In this context, the PDP is exercised by Identity Domains through application authentication and authorization policies, and Network Perimeters operate as contextual constraints on the sign-on process, applicable to users and applications, including confidential applications and OCI services exposing application endpoints. In this case, the PEP is not the control plane API, but the authentication and token issuance service, which denies token issuance or session creation when access conditions are not satisfied. This perimeter remains within the control plane, but governs application flows rather than administrative ones.

OCI Security Architecture: adoption of the Zero Trust model

Formalization of Policy Decision Point (PDP) and Policy Enforcement Point (PEP in Oracle Cloud Infrastructure):

• **In parallel, Oracle Cloud Infrastructure introduces a preventive governance domain, which operates as PDP ex-ante with respect to both access and traffic.** Landing Zones define the architectural and organizational baseline, while Security Zones validate provisioning and resource modification operations against an allowed posture. In this domain, the Policy Enforcement Point coincides with the operation validation mechanism itself, which prevents the execution of non-compliant configurations. Cloud Guard completes this domain by providing continuous detection and response capabilities, operating ex-post while integrating with governance to ensure evidence, traceability, and accountability.

• Within the execution plane (data plane), the PDP/PEP separation governs network communication. Traditional segmentation mechanisms, such as Security Lists and Network Security Groups, act as topological PEPs, enforcing stateful rules based on addresses and ports, with a static

PDP embedded in configuration. However, the Zero Trust Architecture requires enforcement at runtime independent of topology. In OCI, this role is performed by Zero Trust Packet Routing, which constitutes the Policy Enforcement Point of the data plane, applying intent-based decisions per request based on resource identity and attributes. ZPR policies represent the PDP of this domain. Controls such as Network Firewall and Web Application Firewall operate as specialized PEPs at specific inspection points, complementary but not substitutive of Zero Trust enforcement at runtime.

• Taken together, these mechanisms realize a PDP→PEP chain that operates before configuration, before access, during communication, and after the event, in coherence with Zero Trust maturity models and with requirements for control, systemic prevention, and accountability referenced by cloud security frameworks and regulatory standards. In Oracle Cloud Infrastructure, the architectural correctness of Zero Trust Security derives exclusively from the rigorous allocation of decision points and enforcement points within domains where they possess real authority, not from the introduction of numbered layers or artificial taxonomies.

OCI Security Architecture: adoption of the Zero Trust model

Domain	Policy Decision Point (PDP)	Policy Enforcement Point (PEP)
Architectural governance	Landing Zone design rules	Baseline provisioning and validation
Preventive posture	Security Zone recipes	Blocking of non-compliant operations
Detection and response	Cloud Guard detectors	Responders / audit evidence
Infrastructure API access	IAM Allow / Deny Policies, Network Sources	OCI Management APIs
Application sign-on	Identity Domains policies, Network Perimeters	Authentication services / token issuance
Topological segmentation	Security Lists / NSG configuration	VNIC / subnet enforcement
Zero Trust runtime enforcement	ZPR intent policies	Zero Trust Packet Routing
Edge / L7 inspection	WAF / Network Firewall policies	WAF / Network Firewall

OCI Security Architecture: adoption of the Zero Trust model

As defined by NIST SP 800-207, Zero Trust Architecture does not protect network segments but resources, eliminating any implicit trust based on location or membership and rigorously separating authentication and authorization, which must be evaluated before session establishment and continuously re-evaluated over time. NIST does not prescribe firewalls, subnets, or topological perimeters; instead, it introduces the conceptual model of Policy Decision Point and Policy Enforcement Point, namely the distinction between where a security decision is taken and where it is technically enforced, explicitly allowing their distribution across multiple domains. Oracle Cloud Infrastructure faithfully implements this model by adopting a multi-perimeter architecture, in which each perimeter is defined by the protected resource, the timing of the decision, and the actual enforcement point, rather than by a rigid stack of layers. Preventive governance controls, infrastructure API access, application sign-on, and workload communication are governed by distinct yet coherent PDP→PEP chains, while runtime enforcement in the data plane—independent of network topology—fully realizes the NIST principle of protecting resources rather than segments. In this sense, OCI does not superficially adapt the Zero Trust paradigm, but provides an implementation structurally aligned with the principles of decision, enforcement, and absence of implicit trust defined by NIST.

OCI Security Architecture: adoption of the Zero Trust model

Formalization of the Strategic Multi-Perimeter Enforcement System:

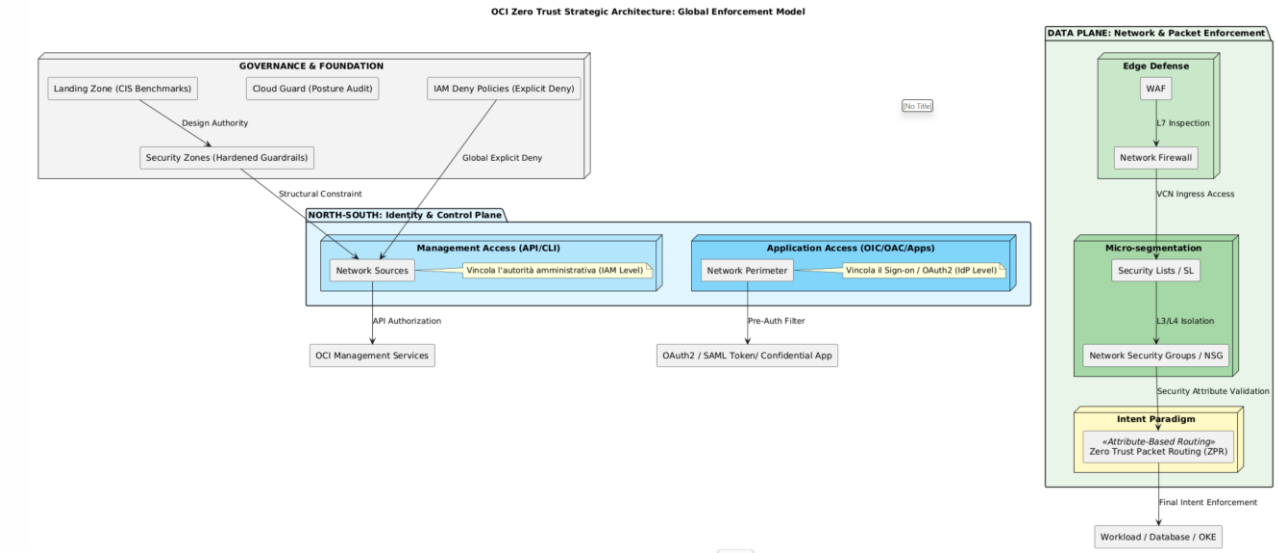
This framework defines the logical security architecture for the Oracle Cloud Infrastructure (OCI) ecosystem, formalizing a model of interlocking perimeters designed for the deterministic neutralization of attack vectors across both the control plane (Control Plane) and the data plane (Data Plane).

The foundation of the system resides in the Landing Zone, conceived as a design authority (Policy Decision Point) that implements the CIS OCI Foundations Benchmarks to establish a verifiable and immutable baseline security posture. The segmentation of enforcement domains is articulated along two fundamental directions:

1. North-South Identity & Access Governance (Control Plane): The protection of management interfaces and integrated services (OIC, OAC, Confidential Apps) is de-localized from the physical network and brought back to the authority plane. Through Network Perimeters in Identity Domains, the issuance of SAML/OAuth2 tokens is constrained by traffic origin (Enterprise Proxy), acting as an identity-aware kill-switch that denies the pre-authentication handshake. In parallel, the integrity of infrastructure APIs is enforced through Network Sources and the recent IAM Deny Policies; the latter introduce a subtractive protection layer that applies the explicit default-deny principle, rendering administrative capabilities inaccessible outside certified IP gateways, regardless of accumulated granted permissions.
2. East-West Intent-Based Enforcement (Data Plane): Workload security moves beyond traditional L3/L4 micro-segmentation. While perimeter defense is ensured by the convergence of WAF and Network Firewall, lateral propagation is neutralized by Zero Trust Packet Routing (ZPR). ZPR operates as a decomposition of the routing plane (Fabric Enforcement), where the reachability of a resource is subordinated to continuous validation of security attributes and communication intent. In this paradigm, network topology (VCN, DRG, NSG) serves purely as a transit substrate, while enforcement decisions are entirely governed by the logical identity of the resource, ensuring full resilience and alignment with NIST SP 800-207 principles and the CISA Zero Trust Maturity Model v2.0.

The entire ecosystem is subjected to continuous audit through Cloud Guard and

protected by Maximum Security Zones, which act as configurative barriers to prevent configuration drift and accidental exposure of critical assets through the enforcement of restrictive and non-bypassable security policies.



Functional Taxonomy and Hierarchy of Enforcement Logics

The OCI security architecture is formalized as a system of layered constraints, where system integrity depends on the correct interaction between Policy Decision Points (PDP) and Policy Enforcement Points (PEP). Within this ontology, security is not a static attribute, but a dynamic process of continuous validation based on the pillars of the NIST SP 800-207 framework and the CISA Zero Trust Maturity Model v2.0.

1. **Control Plane & Governance**

Landing Zone & CIS Compliance Framework:
It constitutes the Root of Trust of the architecture, encoding the CIS OCI Foundations Benchmarks into a deterministic blueprint that defines compartmentalization and initial privilege boundaries.

Cloud Guard & Maximum Security Zones Symbiosis:
These components operate as a coupled system of monitoring and enforcement. While Security Zones impose immutable preventive constraints (for example, mandatory encryption), Cloud Guard acts as the telemetry and detection engine, ensuring that guardrails remain active and are not bypassed through configuration drift.

IAM Policy Engine (Logical Precedence):

- Allow Policies: Define the cumulative permission set according to the principle of Least Privilege.
- Deny Policies: Represent high-priority “subtractive” enforcement. In accordance with Oracle documentation, a Deny Policy has the highest precedence over any Allow instruction, enabling the hardening of critical perimeters against accidental or malicious privilege escalation.

Network Perimeters & Network Sources (Access Control Gateways)

Network Sources bind administrative authority (CLI/SDK access) to specific IP addresses, governing OCI infrastructure API calls authenticated through OCI Signature Version 1.

Network Perimeters operate at the Identity Domain level for Console access, Oracle Integration Cloud (OIC), Oracle Analytics Cloud (OAC), and Confidential Applications sign-on. They prevent the issuance of OAuth2/SAML tokens prior to credential validation if the authentication request originates from outside certified IP boundaries.

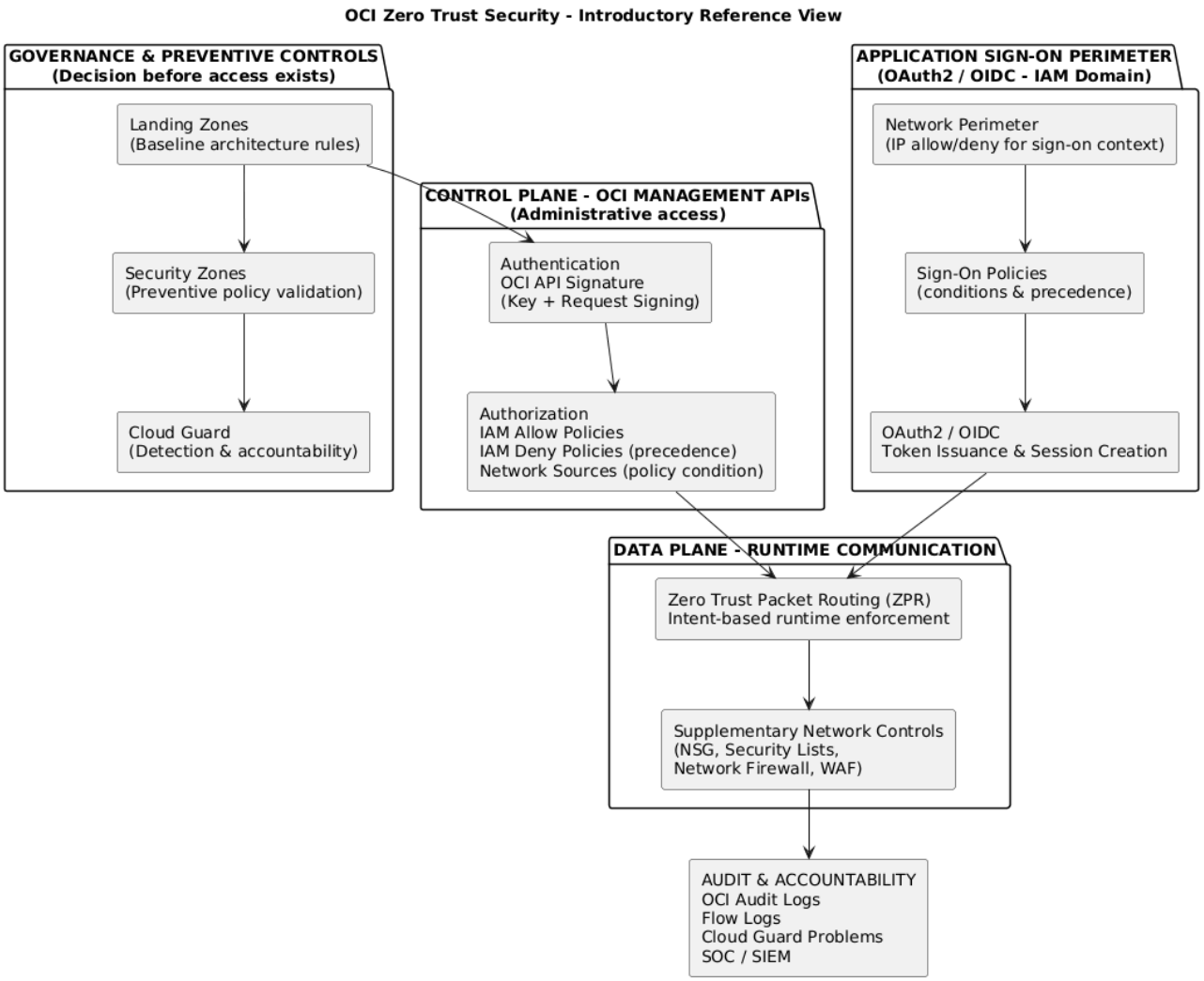
---

2. Data Plane & Fabric Security (Intent & Transit)

Within this domain, enforcement occurs at runtime directly on packet flows traversing the network fabric.

L7 Edge Protection.
The convergence of Web Application Firewall (WAF) and Network Firewall ensures deep inspection of North-South traffic flows, mitigating application-layer attacks and preventing data exfiltration attempts.

Zero Trust Packet Routing (ZPR – Intent-Based Enforcement).
ZPR represents the definitive paradigm shift in network security architecture. It decouples security enforcement from physical topology constructs (IP/Subnet/VCN), transforming routing into a direct function of Security Attributes. If the defined security contract between attributes (for example, App Tier and Database Tier) is not validated, the packet is discarded at the origin within the OCI Software-Defined Networking (SDN) fabric.



OCI Zero Trust Security Architecture: Identity, Governance, and Intent-Based Enforcement Model

Network Security and Zero Trust

1. Governance & Foundation – Ex-Ante Constraints and Design Authority

In the Zero Trust model, the primary mechanism for risk reduction is not traffic inspection, but the systematic elimination of inherently insecure configurations before sessions, tokens, or traffic flows can exist.

Within Oracle Cloud Infrastructure, this domain is represented by the combined framework of Landing Zones, Security Zones, and Cloud Guard, each fulfilling distinct yet complementary roles. Landing Zones establish the architectural and governance baseline, including compartment hierarchy, separation of network and workload domains, centralized logging, and tagging strategies. Security Zones translate security posture requirements into non-bypassable preventive constraints

on provisioning and modification operations. Cloud Guard introduces continuous detection, monitoring, and accountability capabilities.

In this domain, Zero Trust operates “ex-ante.” The system reduces exposure probability by preventing resources from being created or modified outside an approved security posture. This approach is fully aligned with the NIST definition of resource-centric protection and with maturity models that require posture management and visibility as transversal foundational capabilities.

---

2. North–South: Identity & Control Plane – Management Access (API/CLI)

The administrative Control Plane in Oracle Cloud Infrastructure is governed by a model in which authentication and authorization are distinct, independently verifiable functions evaluated prior to the execution of any infrastructural operation.

Authentication of API and CLI calls is performed through OCI API Signature (API key combined with request signing), rendering each request cryptographically verifiable and independent of network location.

Authorization is determined by IAM Policies, with strict adherence to the principle of least privilege and the presence of IAM Deny Policies operating as absolute precedence constraints (“explicit deny”). An explicit deny functions as a non-bypassable hard stop: if a deny policy matches the request, the operation must fail regardless of any concurrent allow policies.

Within this context, Network Sources do not represent a login mechanism. Rather, they constitute a policy condition restricting the ability to invoke administrative operations based on the network origin of the signed request. They therefore bind administrative authority at the IAM level and provide deterministic control over the API/CLI channel.

Effective enforcement (Policy Enforcement Point – PEP) is implemented by OCI Management Services, which reject any call that does not conform to IAM Policy Decision Point (PDP) determinations.

3. North–South: Identity & Control Plane – Application Access (OIC/OAC/Apps)

The application perimeter is conceptually distinct from management access. Oracle Integration Cloud (OIC) and Oracle Analytics Cloud (OAC), and more broadly PaaS services protected by Identity Domains, are accessed through OAuth2/OIDC flows in which the IAM Domain acts as the Authorization Server and Identity Provider (IdP).

Within this domain, the primary control mechanism is not the Network Source (which governs infrastructure API access), but rather the Network Perimeter. The Network Perimeter is a native Identity Domain control that defines explicit sets of allowed or denied IP addresses, ranges, or CIDR blocks. It is enforced during OAuth2/OIDC flows as a pre-authentication and pre-token issuance filter.

From both an operational and architectural perspective, a Network Perimeter produces effect only when explicitly referenced within a Sign-On Policy rule. Such a rule defines precedence and contextual conditions and is associated with the corresponding Cloud Service Applications representing the services (for example, OIC and OAC), which the Identity Domain automatically generates for each instance under the “Oracle Cloud Services” section.

This results in deterministic behavior. If access to the service console via browser initiates an OIDC flow (scope = openid) and the originating IP address falls outside the defined Network Perimeter, the IAM Domain blocks session creation and prevents redirection to the service instance. Similarly, when invoking REST endpoints, the client must first obtain an OAuth2 access token; the issuance of such a token can be denied if the originating IP does not comply with the configured perimeter.

3.1 Network Perimeter and Application Sign-On (OCI IAM Domain, OAuth2 / OpenID Connect)

In Oracle Cloud Infrastructure, the Network Perimeter is an Identity Domain control that operates exclusively within the authentication and authorization domain of OAuth2 and OpenID Connect flows. It does not function at the network layer nor within the infrastructural control plane. Its objective is to constrain who may complete a sign-on process or obtain an access token based on the client’s source IP address, with enforcement occurring prior to the creation of any application session or the issuance of any token.

From an architectural standpoint, the Network Perimeter is not evaluated autonomously. It is enforced solely through the Identity Domain’s Sign-On Policies, which constitute the formal Policy Decision Point (PDP) for all OAuth2 and OIDC flows. Each Sign-On Policy Rule may include one or more Network Perimeters as contextual conditions, alongside additional criteria such as application type, authentication method, and rule precedence.

When an authentication request reaches the Identity Domain, the sign-on engine evaluates the applicable policy. If the client’s IP address does not fall within the Network Perimeter associated with the rule, the request is deterministically denied before session creation or token issuance occurs.

This model applies uniformly to the Cloud Service Applications automatically generated for OCI services such as Oracle Integration Cloud (OIC) and Oracle Analytics Cloud (OAC). It is valid for both browser-based OIDC flows (service console access) and non-browser OAuth2 flows used for REST endpoint access. In all cases, the Identity Domain acts as the Authorization Server, and the Network Perimeter is evaluated upstream of the sign-on process, prior to the release of any access credential.

3.1 Network Perimeter and Application Sign-On (OCI IAM Domain, OAuth2 / OpenID Connect)

The same enforcement mechanism extends to Confidential Applications registered within the Identity Domain, typically used by application clients or machine-to-machine integrations. During the execution of OAuth2 grants (for example, Authorization Code, Device Flow, or other supported equivalent flows), the Network Perimeter is evaluated as part of the Sign-On Policy. If the request originates from a non-authorized IP address, the Authorization Server denies the operation and no token is issued.

As a consequence, access to OIC/OAC application APIs fails before traffic reaches the service, achieving pre-token and pre-session enforcement.

Within the Zero Trust model, the Network Perimeter therefore represents a Policy Enforcement Point (PEP) at the Identity Provider level. It is distinct from Network Sources (which operate as IAM policy conditions governing infrastructural API access) and from network-layer controls within the data plane. Source IP verification is not a topological control nor a local application-layer control; rather, it is an authentication-context attribute fully aligned with the NIST SP 800-207 principle of pre-session decision-making and with the OCI approach of protecting application resources without implicit trust in the network.

---

4. Data Plane: Network & Packet Enforcement – Segmentation, Edge, and Intent Enforcement

Within the Data Plane, the dominant attack surface is lateral propagation (east-west movement) and unauthorized traversal of application boundaries.

Topological controls such as Security Lists and Network Security Groups (NSGs) provide L3/L4 micro-segmentation and subnet/VNIC-level isolation. Edge and inspection controls—namely Web Application Firewall (WAF) and Network Firewall—deliver protection respectively at the HTTP(S) application layer and at the network inspection layer at strategic ingress and egress points.

However, the Zero Trust core of runtime enforcement in OCI is Zero Trust Packet Routing (ZPR), which implements an intent-based and attribute-centric model. Policies express “who can communicate with whom” in terms of resource identities and security attributes, and are enforced at runtime consistently even when topology changes.

Within this architecture, ZPR constitutes the final intent enforcement point prior to packet delivery to the workload, while traditional controls operate as complementary and specialized Policy Enforcement Points. The result is a data plane that does not rely on static network segments as a basis of trust, but on communication authorization decisions centered on resource identity and attributes.

---

5. Audit & Accountability – Evidence, Attribution, and Lifecycle Closure

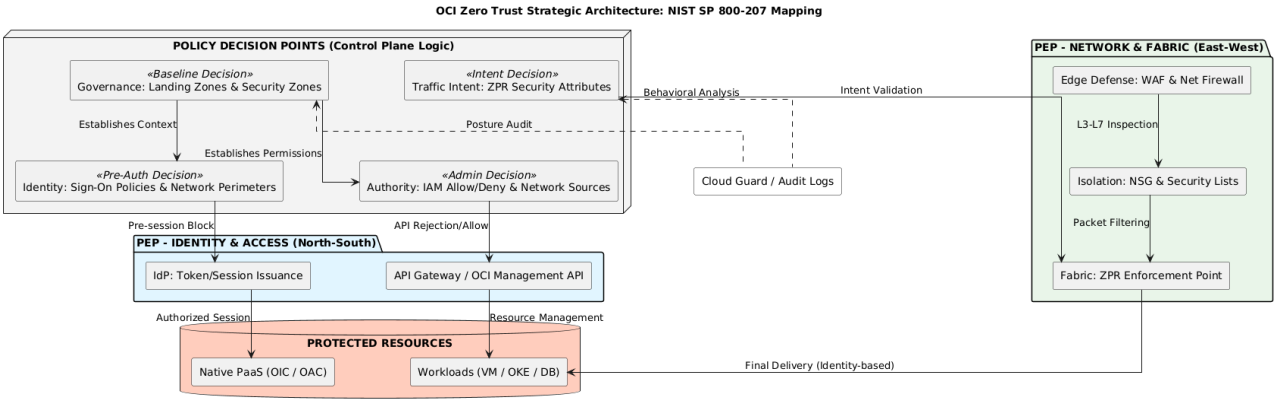
A complete Zero Trust model must generate verifiable evidence of decisions and actions, enabling auditing and incident response.

In Oracle Cloud Infrastructure, this requires correlation among control plane events (Audit Logs), network telemetry (Flow Logs, where enabled), and detection signals (Cloud Guard Problems), integrated with SOC/SIEM pipelines.

Although this domain is not a primary access decision point, it is essential to sustain accountability, investigation, and remediation capabilities, ensuring that the architecture remains verifiable, governable, and continuously defensible over time.

Mapping formale NIST SP 800-207 → PDP / PEP → Oracle Cloud Infrastructure

Principio NIST SP 800-207	Decisione (PDP)	Enforcement (PEP)	Strumenti OCI (allocazione reale)
Proteggere le **risorse**, non i segmenti di rete	Definizione di risorsa e attributi ammessi	Blocco deterministico dell'azione non conforme	Security Zones (recipes), ZPR (resource attributes)
Nessuna fiducia implicita basata su posizione di rete	Valutazione contesto (identità, origine, policy)	Rifiuto accesso/sessione	IAM Policies, Network Sources, Network Perimeters
Autenticazione ≠ Autorizzazione	Motore decisionale IAM / Identity Domain	API / Token issuance	API Signature + IAM Allow/Deny, Sign-On Policies
Decisione **prima** della sessione	Policy evaluation ex-ante	Nessuna sessione/token emesso	Sign-On Policies + Network Perimeter
Decisione **per richiesta** (continuous evaluation)	Intent policy evaluation	Enforcement runtime	ZPR (per-request enforcement)
Separazione PDP / PEP	Motori decisionali distinti	Enforcement distribuito	IAM (PDP), APIs / IdP / ZPR (PEP)
Riduzione superficie d'attacco strutturale	Baseline architetturale	Blocco configurazioni non ammesse	Landing Zones, Security Zones
Governance come parte della sicurezza	Regole preventive di configurazione	Validazione provisioning	Security Zones
Monitoraggio continuo e accountability	Analisi eventi e posture	Evidenza / risposta	Cloud Guard, Audit Logs
Protezione accesso amministrativo	Policy IAM + condizioni	API rejection	IAM Allow/Deny + Network Sources
Protezione accesso applicativo	Sign-On Policy + contesto	Token/session denial	Network Perimeter + Sign-On Policies
Protezione traffico east-west	Intent decision	Packet-level enforcement	ZPR
Difesa in profondità L3–L7	Regole di ispezione	Filtering/inspection	NSG, Security Lists, Network Firewall, WAF



OCI Security Tools: Technical Taxonomy and Mapping to NIST SP 800-207

OCI Landing Zones

OCI Landing Zones represent the ex-ante Zero Trust perimeter of the OCI architecture, translating security, compliance, and governance requirements into an enforceable architectural baseline. They operate before operational identities, sessions, or traffic flows exist, thereby reducing structural attack surface and preventing systemic misconfigurations.

Under the NIST SP 800-207 framework, Landing Zones do not constitute a Policy Enforcement Point (PEP) for access control, but rather an architectural prevention mechanism that protects resources by disallowing inherently untrusted configurations. They define compartment hierarchy, segregation of network and workload domains, mandatory logging, tagging strategies, and identity boundaries, establishing the deterministic context within which subsequent Zero Trust controls operate.

Reference:
https://docs.oracle.com/en/solutions/cis-oci-benchmark/index.html

---

OCI Security Zones

Security Zones implement a preventive Policy Decision Point (PDP) applied to resource provisioning and modification operations. Each action is validated against security recipes (Cloud Guard–based) that codify requirements for encryption, isolation, logging, and non-exposure.

The Policy Enforcement Point coincides with the validation engine itself, which blocks non-compliant operations before a resource is created or modified. This model extends Zero Trust beyond access and traffic control by treating resource configuration as a primary protection object, fully aligned with the NIST principle of pre-session decision-making.

Reference:
https://docs.oracle.com/en-us/iaas/Content/security-zone/using/security-zones.htm

---

OCI Cloud Guard

Cloud Guard provides visibility, detection, and accountability across the entire OCI environment. It is not an access PEP, but an ex-post evidence and response mechanism essential to sustaining the Zero Trust principle of continuous monitoring.

Through detectors, responders, and targets, Cloud Guard correlates configuration, identity, and network events, generating verifiable signals for SOC and SIEM integration. Within the CISA Zero Trust Maturity Model (ZTMM), it aligns with the transversal capabilities of visibility and analytics, closing the decision → enforcement → observability lifecycle.

Reference:
https://docs.oracle.com/en-us/iaas/Content/cloud-guard/using/cg-concepts.htm

---

IAM Allow and Deny Policies

IAM Policies constitute the central Policy Decision Point of the OCI control plane. Allow Policies define the minimal authorization perimeter in accordance with the principle of least privilege. Deny Policies, introduced subsequently, impose a hard stop with absolute precedence that cannot be overridden by any Allow rule.

This mechanism enables the implementation of global and irreversible security constraints, consistent with NIST requirements for decision/enforcement separation and with regulatory frameworks such as NIS2.

The Policy Enforcement Point is directly represented by the OCI Management APIs, which reject any non-compliant request.

Reference:
https://docs.oracle.com/en-us/iaas/Content/Identity/policysyntax/denypolicies.htm

---

OCI IAM Network Sources

Network Sources are IAM policy conditions, not login perimeters. They constrain the execution of infrastructural APIs based on network origin (IP address, VCN, CIDR range) and apply exclusively to administrative access through API, CLI, or SDK interactions.

From a Zero Trust perspective, they introduce origin context into the control plane PDP decision without assuming implicit trust based on network location. The PEP remains the OCI API itself; the Network Source qualifies the request but does not manage sessions or tokens.

Reference:
https://docs.oracle.com/en-us/iaas/Content/Identity/networksources/Introduction_to_Network_Sources.htm

---

OCI IAM Network Perimeters

Network Perimeters operate at the Identity Domain level and are evaluated exclusively through Sign-On Policies during OAuth2 and OpenID Connect flows. They protect Cloud Service Applications (such as Oracle Integration Cloud and Oracle Analytics Cloud), Confidential Applications, and both browser-based and non-browser-based access patterns by blocking sign-on or token issuance when the originating IP address is not permitted.

They represent an Identity Provider–level Policy Enforcement Point, distinct from both Network Sources and network-layer controls. Enforcement is pre-token and pre-session, fully aligned with NIST SP 800-207 principles.

References:
https://docs.oracle.com/en-us/iaas/Content/Identity/networkperimeters/overview.htm
https://docs.oracle.com/en-us/iaas/Content/Identity/signonpolicies/managingsignonpolicies.htm

Real-world use case for restricting access to Oracle Integration Cloud (OIC) and Oracle Analytics Cloud (OAC) using Network Perimeters:
https://www.ateam-oracle.com/oci-iam-domain-network-perimeter-use-case-restricting-access-to-oci-paas-services-such-as-oic-and-oac

Zero Trust Packet Routing (ZPR)

Zero Trust Packet Routing (ZPR) represents the runtime Policy Enforcement Point (PEP) of the OCI data plane. It applies per-request enforcement based on resource identity and security attributes, rather than on IP addresses or network topology.

Policies express permitted communication intent between resources, governing both east–west and internal north–south traffic. ZPR directly implements the NIST SP 800-207 principle of protecting resources rather than network segments and significantly reduces the impact of network misconfigurations through an attribute-based access control (ABAC) model.

Its architecture is intent-based and attribute-centric, with security attributes evaluated and enforced directly within the data plane at runtime.

References:
https://docs.oracle.com/en-us/iaas/Content/zero-trust-packet-routing/overview.htm
https://docs.oracle.com/en/learn/config-oci-zpr/index.html

Network Security Groups (NSGs) and Security Lists

Network Security Groups and Security Lists implement L3/L4 topological segmentation within the OCI data plane. They function as traditional Policy Enforcement Points based on IP addresses and ports. While effective, their correctness depends on the integrity of IP design and subnet architecture.

Within the OCI Zero Trust model, they do not constitute the foundation of trust but operate as complementary controls to ZPR, supporting baseline isolation and defense-in-depth strategies.

A Network Security Group (NSG) can be defined as a virtual firewall composed of ingress and egress security rules applied to a defined set of VNICs within a single Virtual Cloud Network (VCN).

Security Lists are subnet-scoped controls whose rules are enforced on each VNIC within the subnet, whereas Network Security Groups provide explicit, fine-grained VNIC-level enforcement independent of subnet boundaries.

References:
https://docs.oracle.com/en-us/iaas/Content/Network/Concepts/networksecuritygroups.htm
https://docs.oracle.com/en-us/iaas/Content/Network/Concepts/securitylists.htm

---

OCI Network Firewall

OCI Network Firewall provides advanced Layer 3 through Layer 7 inspection and threat prevention within the data plane. It operates as a specialized Policy Enforcement Point at defined choke points, complementing the intent-based enforcement model of ZPR. It is particularly relevant for on-premises integrations, north–south traffic control, and deep inspection requirements.

OCI Network Firewall is a managed service that delivers centralized traffic inspection and control within a Virtual Cloud Network. It is designed as a stateful Layer 3 and Layer 4 network control, integrating advanced inspection capabilities up to Layer 7, including intrusion prevention, application awareness, and signature-based detection.

Policies are enforced at dedicated enforcement points, enabling consistent governance of north–south traffic and selected east–west flows. The service supports features such as policy-based routing and integration with threat intelligence feeds.

Within the OCI Zero Trust model, Network Firewall operates as a specialized Policy Enforcement Point that complements, but does not replace, identity-centric and intent-based controls.

Reference:
https://docs.oracle.com/en-us/iaas/Content/network-firewall/overview.htm

OCI Web Application Firewall (WAF)

OCI Web Application Firewall (WAF) protects exposed HTTP and HTTPS applications by providing Layer 7 security against application-layer attacks. Within the OCI Zero Trust model, it does not replace identity-centric enforcement but operates as an edge application Policy Enforcement Point (PEP), complementary to identity and runtime controls.

OCI WAF is a Layer 7 application security control that functions as a Policy Enforcement Point for HTTP and HTTPS traffic directed toward exposed application resources, typically through an OCI Load Balancer. It is natively integrated with OCI Load Balancers and operates in architectural symbiosis, intercepting traffic before it reaches backend application workloads.

The service provides protection against OWASP Top 10 vulnerabilities, injection attacks, cross-site scripting (XSS), malicious bots, and protocol anomalies. Its inspection engine operates primarily at Layer 7, while leveraging Layer 3 and Layer 4 network flows already established by the Load Balancer, thereby ensuring consistent enforcement without introducing additional topological complexity.

WAF policies are based on deterministic rules, continuously updated signatures, and behavioral controls. Enforcement is stateless per request, consistent with Zero Trust principles of continuous evaluation. The WAF does not assume implicit trust in the originating network; instead, it evaluates each application request individually.

Within an OCI Zero Trust Architecture (ZTA), WAF functions as an edge application PEP, complementary to identity-centric controls such as IAM and runtime enforcement mechanisms such as ZPR. It does not replace identity or segmentation controls but strengthens the protection of exposed application surfaces. Its appropriate architectural placement is at the application edge, serving as the final defensive control before traffic reaches the workload.

Reference:
https://docs.oracle.com/en-us/iaas/Content/WAF/home.htm

OCI Security Tools: Technical Taxonomy and Mapping to NIST SP 800-207 and ISO/IEC 27001 Annex A

The following table formalizes the OCI security ontology by deterministically mapping each security capability to the paradigms defined in NIST SP 800-207 and to the regulatory directives of NIS2 and ISO/IEC 27001 Annex A. The framework establishes a structured enforcement hierarchy in which policy decision (Policy Decision Point – PDP) systematically precedes technical execution (Policy Enforcement Point – PEP), thereby ensuring a structurally grounded Zero Trust posture.

The strategic architecture of Oracle Cloud Infrastructure (OCI) formalizes the Zero Trust paradigm through a rigorous decomposition between Control Plane and Data Plane, aligning each component with the Policy Decision Point (PDP) and Policy Enforcement Point (PEP) roles defined by NIST SP 800-207.

Structural governance is established ex-ante through Landing Zones and Security Zones, which operate as configurational PDPs to ensure baseline integrity. Identity security is enforced within the Control Plane through Sign-On Policies and Network Perimeters, which function as Identity Provider–level PEPs, preventing token issuance prior to session establishment. In parallel, IAM Deny Policies and Network Sources govern administrative authority over infrastructural APIs with absolute precedence.

Simultaneously, the Data Plane evolves toward an intent-based enforcement model through Zero Trust Packet Routing (ZPR), which operates as a runtime PEP validating packet transit based on resource attributes, thereby overcoming the structural limitations of purely topological micro-segmentation mechanisms such as Network Security Groups and Security Lists.

This ecosystem is continuously validated through Cloud Guard and Audit Log analytics, which provide the accountability, traceability, and continuous monitoring capabilities required to satisfy NIS2 and ISO/IEC 27001 compliance requirements.

OCI Security Tools: Technical Taxonomy and Mapping to NIST SP 800-207 and ISO/IEC 27001 Annex A

Tabella di Mapping

OCI Security Tool	Ruolo	NIS2 – Art./Req.	ISO 27001 – Annex A (2022)	Razionale di conformità
OCI Landing Zones	PDP (ex-ante)	Art. 21(2)(a)(d)	A.5.1, A.5.23, A.8.1	Definiscono baseline di sicurezza, segregazione ambienti, logging e governance preventiva prima dell'uso delle risorse.
OCI Security Zones	PDP + PEP	Art. 21(2)(a)(c)	A.5.23, A.8.9	Impongono controlli preventivi su configurazioni non conformi, realizzando sicurezza by-design e by-default.
OCI Cloud Guard	Detection / Evidence	Art. 21(2)(e)(f)	A.5.7, A.8.16, A.8.23	Fornisce monitoraggio continuo, rilevazione anomalie, evidenza e supporto alla risposta agli incidenti.
IAM Allow Policies	PDP	Art. 21(2)(b)	A.5.15, A.8.2	Implementano controllo degli accessi basato su least privilege per risorse e servizi.
IAM Deny Policies	PDP (hard stop)	Art. 21(2)(b)(d)	A.5.15, A.5.18	Consentono restrizioni globali non aggirabili, rafforzando la separazione dei privilegi.
OCI API Signature	AuthN mechanism	Art. 21(2)(b)	A.8.5	Garantisce autenticazione forte e non ripudiabile per l'accesso alle API infrastrutturali.
IAM Network Sources	PDP (context)	Art. 21(2)(b)	A.8.21	Introducono restrizioni di contesto sull'accesso amministrativo basate sull'origine.
Sign-On Policies (IAM Domain)	PDP	Art. 21(2)(b)(c)	A.5.15, A.8.2	Centralizzano la decisione di accesso per flussi OAuth2/OIDC, applicando condizioni e precedenze.
IAM Network Perimeters	PEP (IdP-level)	Art. 21(2)(b)	A.8.21	Limitano sign-on e token issuance per applicazioni OCI e client OAuth in base all'origine IP.
Zero Trust Packet Routing (ZPR)	PEP (runtime)	Art. 21(2)(a)(d)	A.8.20, A.8.21	Applica enforcement intent-based per comunicazioni tra risorse, indipendente dalla topologia IP.
Network Security Groups (NSG)	PEP (L3/L4)	Art. 21(2)(a)	A.8.20	Forniscono segmentazione di rete fine-grained per workload e VNIC.
Security Lists (SL)	PEP (L3/L4)	Art. 21(2)(a)	A.8.20	Implementano controlli di rete di base a livello subnet, come difesa in profondità.
OCI Network Firewall	PEP (L3–L7)	Art. 21(2)(a)(e)	A.8.20, A.8.23	Abilita ispezione avanzata del traffico e prevenzione delle minacce in punti di choke-point.
OCI Web Application Firewall (WAF)	PEP (L7)	Art. 21(2)(a)(e)	A.8.20, A.8.23	Protegge applicazioni web da attacchi applicativi e vulnerabilità note.
OCI Audit Logs	Evidence	Art. 21(2)(f)	A.5.7, A.8.15	Garantisce tracciabilità, accountability e supporto alle indagini di sicurezza.

OCI Zero Trust Architecture (ZTA) – NIST SP 800-207 PDP / PEP View

The following diagram rigorously represents the implementation of the Zero Trust paradigm within Oracle Cloud Infrastructure, explicitly aligning the Control Plane and Data Plane with the Policy Decision Point (PDP) and Policy Enforcement Point (PEP) concepts defined by NIST SP 800-207. The architecture assumes no implicit trust in the network or in the positional placement of resources; every decision is instead based on identity, contextual attributes, and dynamically evaluated policy.

The Governance & Prevention section describes the ex-ante Zero Trust layer, operating prior to the existence of operational identities, sessions, or traffic flows. OCI Landing Zones function as the architectural baseline PDP, deterministically defining compartment structure, network domain segregation, logging and tagging policies, and identity boundaries. OCI Cloud Guard provides detection and evidence capabilities and is correctly modeled as a prerequisite control supporting Security Zones. OCI Security Zones operate as both preventive PDP and PEP, validating each provisioning operation and blocking the creation or modification of resources that do not comply with defined security recipes. IAM Deny Policies introduce a global hard-stop PDP with absolute precedence, non-overridable by any Allow policy, thereby ensuring immutability of critical security decisions.

The OCI Control Plane is modeled as an administrative north–south flow governed exclusively by identity and policy. Authentication to OCI Management APIs occurs through OCI API Signature, providing strong cryptographic authentication without reliance on session-based trust. IAM Allow Policies constitute the authorization PDP in accordance with the principle of least privilege, while IAM Network Sources introduce source-origin context as a policy condition without acting as a login perimeter. OCI Management APIs operate as the effective PEP of the control plane, accepting or rejecting requests based on PDP decisions, with Deny Policies applied with absolute priority.

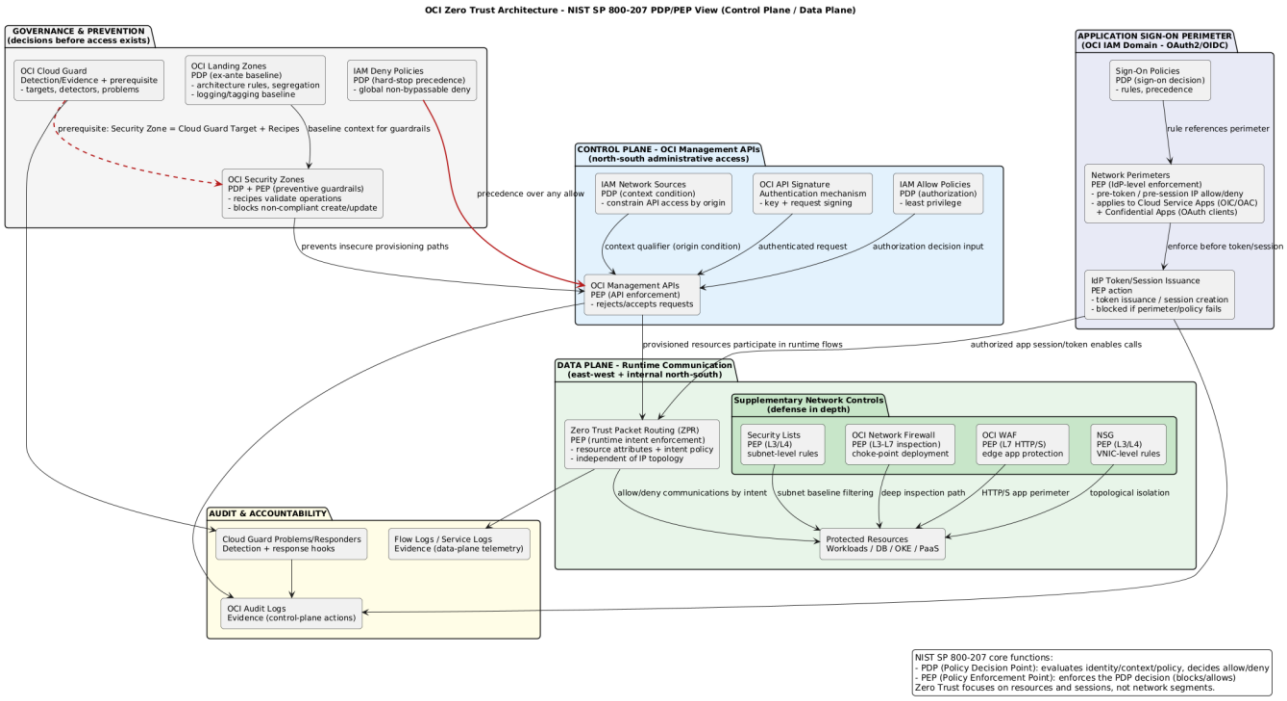
The Application Sign-On perimeter is clearly separated from the infrastructural control plane and positioned at the Identity Domain level. Sign-On Policies represent the formal PDP for all OAuth2 and OpenID Connect flows. Network Perimeters operate as Identity Provider–level PEPs rather than network-layer controls, blocking sign-on or token issuance prior to session creation. This pre-token and pre-session enforcement applies uniformly to OCI Cloud Service Applications such as Oracle Integration Cloud (OIC) and Oracle Analytics Cloud (OAC), to browser-based service console access, and to Confidential Applications used by non-browser OAuth clients. The model clarifies that the Network Perimeter protects the act of token issuance itself, not merely a user interface, fully consistent with the Zero Trust paradigm.

Within the Data Plane, the architecture evolves toward an intent-based runtime enforcement model. Zero Trust Packet Routing (ZPR) functions as the primary PEP of the data plane, enforcing communication policies based on resource attributes and declared intent, independently of IP topology or static network segmentation. Network Security Groups and Security Lists are correctly modeled as complementary Layer 3/Layer 4 PEPs—topological rather than identity-centric—providing baseline isolation but not forming the foundation of

trust. OCI Network Firewall and OCI Web Application Firewall operate as specialized PEPs for advanced Layer 3–Layer 7 inspection and Layer 7 application protection respectively, contributing to defense-in-depth rather than serving as primary policy decision mechanisms.

The Audit & Accountability section closes the Zero Trust lifecycle of decision, enforcement, and evidence. OCI Audit Logs ensure traceability of control plane actions, while Flow Logs and Service Logs provide telemetry for the data plane. Cloud Guard Problems and Responders correlate configuration, identity, and network events, supplying the evidentiary foundation required for SOC integration, SIEM correlation, and incident response. This layer satisfies the continuous monitoring principle mandated by NIST SP 800-207 and by regulatory frameworks such as NIS2 and ISO/IEC 27001.

Overall, the diagram represents a coherent and comprehensive formalization of Zero Trust Architecture within OCI, with a clear decomposition between PDP and PEP roles, strict separation among Control Plane, Identity Plane, and Data Plane, and an enforcement model centered on resource identity and session validation rather than static network segmentation.



1) Control Plane & Identity Plane: L'autorità di Accesso (PDP/PEP)

In questo ambito, la distinzione tra Identity Domain (autenticazione applicativa) e OCI Management APIs (amministrazione infrastrutturale) è fondamentale.

- **Scenario Login (Sign-On):** Il PDP è la Sign-On Policy. Il Network Perimeter qui serve a decidere se un utente può atterrare in console o in un'app OCI (OIC/OAC) tramite browser. Il PEP è l'emissione del token di sessione.
- **Scenario M2M/Confidential App (OIC/OAC**): Come evidenziato nella tabella seguente, il Network Perimeter si aggancia alla Confidential Application. Il PEP è

l'emissione del token OAuth2. Se l'IP non è nel perimetro, il token non viene emesso e il traffico non raggiunge nemmeno il servizio target.

- **Scenario Infrastrutturale (Control Plane):** Per gli Instance Principal (IN-1) e Resource Principal (IN-2..11), l'autenticazione è basata sul certificato della risorsa. Il PDP è la IAM Policy Engine e il vincolo corretto è la Network Source (IAM), non il Network Perimeter, perché stiamo parlando di chiamate alle API di gestione OCI.

Ambito	Attore / Scenario	Meccanismo PEP	Vincolo (Network Context)	PDP (Decisione)
Login / Sign-in	Utente Umano	IdP Session Issuance	**Network Perimeter**	Sign-On Policies
M2M / API App	Confidential App / OIC REST	OAuth2 Token Issuance	**Network Perimeter**	App Configuration
OCI Admin	Tool/CLI (API Key)	OCI Management APIs	**Network Source (IAM)**	IAM Policies
OCI Internal	Instance/Resource Principal	OCI Management APIs	**Network Source (IAM)**	IAM Policies
Traffic Fabric	East-West (VM to DB)	**ZPR Enforcement**	Security Attributes	ZPR Policies

Authentication & Authorization Access Patterns (Inside OCI vs Outside OCI – Control Plane, Identity Domain, Data Plane)

SCENARI PATTERN — FUORI DA OCI
(EXTERNAL → OCI)

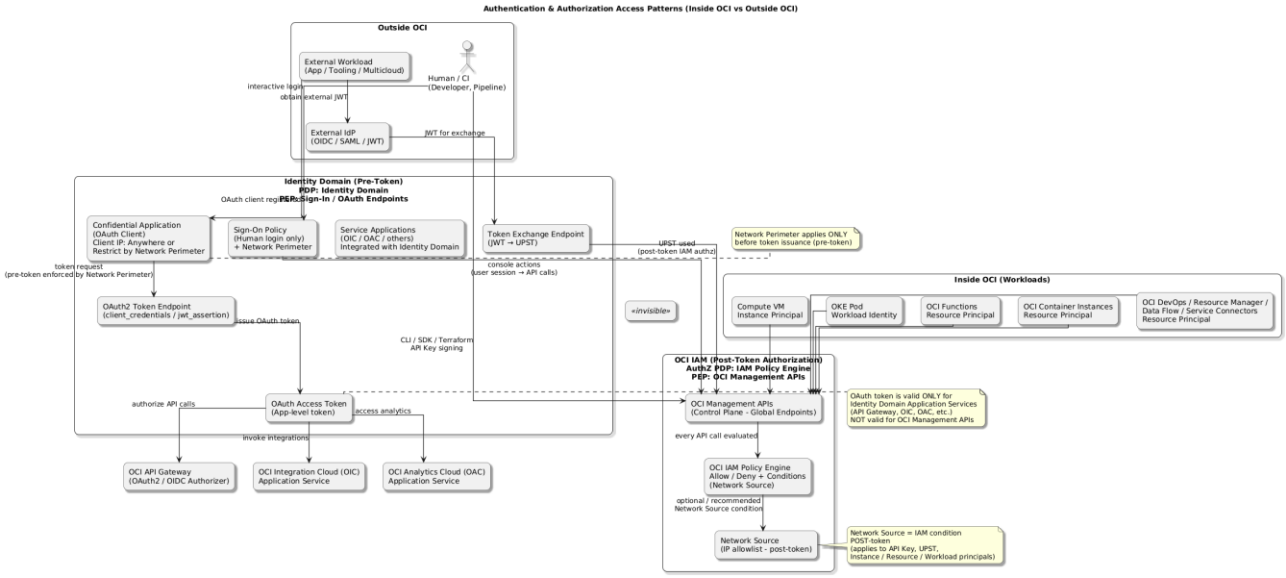
#	Scenario	Origine	Pre-Token (Identity Domain)	Token	AuthZ PDP	PEP	Vincoli corretti
EXT-1	Tool umano / CI → OCI APIs	Outside OCI	—	**API Key**	**OCI IAM**	OCI Management APIs	**Network Source (IAM)**
EXT-2	External App → OCI APIs (no static keys)	Outside OCI	**OAuth2 Token Exchange**	**UPST**	**OCI IAM**	OCI Management APIs	**Network Perimeter (pre-token)** + **Network Source (post-token)**
EXT-3	External App → OCI via **Token Broker** (API GW / Function)	Outside OCI	**Confidential App (jwt_assertion / client_credentials)**	OAuth Access Token → **UPST**	**OCI IAM**	OCI Management APIs	**Network Perimeter** (token) + **Network Source** (IAM)
EXT-4	External App → OIC / OAC APIs	Outside OCI	**Confidential / Service Application**	OAuth Access Token	**Identity Domain**	Service Frontend	**Network Perimeter**
EXT-5	External IdP → OCI Federation	Outside OCI	**Federation / Exchange**	OCI Token	**OCI IAM**	OCI Management APIs	**Network Perimeter** + **Network Source**

SCENARI PATTERN — DENTRO OCI
(INSIDE → OCI CONTROL PLANE)

#	Runtime OCI	Principal	Token	AuthN PDP	AuthZ PDP	PEP	Vincoli corretti
IN-1	Compute VM	**Instance Principal**	Instance Security Token	OCI IAM	OCI IAM Policy Engine	OCI Management APIs	**Network Source (IAM)**
IN-2	OCI Functions	**Resource Principal**	Resource Session Token	OCI IAM	OCI IAM Policy Engine	OCI Management APIs	**Network Source (IAM)**
IN-3	OCI Container Instances	**Resource Principal**	Resource Session Token	OCI IAM	OCI IAM Policy Engine	OCI Management APIs	**Network Source (IAM)**
IN-4	OKE Pod (Workload Identity)	**Workload Principal**	Pod-bound Token	OCI IAM	OCI IAM Policy Engine	OCI Management APIs	**Network Source (IAM)**
IN-5	OCI DevOps (Build / Deploy)	**Resource Principal**	Resource Session Token	OCI IAM	OCI IAM Policy Engine	OCI Management APIs	**Network Source (IAM)**
IN-6	OCI Resource Manager (Stacks/Jobs)	**Resource Principal**	Resource Session Token	OCI IAM	OCI IAM Policy Engine	OCI Management APIs	**Network Source (IAM)**
IN-7	OCI Streaming Service Connector	**Resource Principal**	Resource Session Token	OCI IAM	OCI IAM Policy Engine	OCI Management APIs	**Network Source (IAM)**
IN-8	OCI Data Flow (App / Run)	**Resource Principal**	Resource Session Token	OCI IAM	OCI IAM Policy Engine	OCI Management APIs	**Network Source (IAM)**
IN-9	OCI GoldenGate	**Resource Principal**	Resource Session Token	OCI IAM	OCI IAM Policy Engine	OCI Management APIs	**Network Source (IAM)**
IN-10	OCI Integration Cloud (runtime)	**Resource Principal**	Resource Session Token	OCI IAM	OCI IAM Policy Engine	OCI Management APIs	**Network Source (IAM)**
IN-11	OCI Analytics Cloud (jobs/exports)	**Resource Principal**	Resource Session Token	OCI IAM	OCI IAM Policy Engine	OCI Management APIs	**Network Source (IAM)**

DATA PLANE — RUNTIME TRAFFIC
(NON IAM / NON OAUTH)

Scenario	Plane	PDP	PEP	Note
East-West workload	L3/L4	ZPR Policy Engine	**ZPR**	Identity-based enforcement
North-South choke	L3–L7	Firewall Policy	Network Firewall	Threat/IPS
HTTP/S	L7	WAF Policy	**WAF**	OWASP/Bot
Subnet/VNIC	L3/L4	NSG / SL	VNIC	Coarse segmentation



Positioning of Landing Zones, Security Zones, Cloud Guard, and Threat Intelligence within the OCI Zero Trust Model

Within the adopted OCI Zero Trust model, Landing Zones, Security Zones, Cloud Guard, and Threat Intelligence do not introduce additional runtime enforcement planes. Rather, they operate as foundational and transversal layers of governance, prevention, and detection, complementing the Control Plane, Identity Domain, and Data Plane controls previously described.

The Landing Zone represents the design-time governance layer. It deterministically defines compartment structure, network segmentation, baseline IAM policies, mandatory enablement of Cloud Guard, and initial perimeter controls (including Network Sources, logging, and audit configuration). It constitutes the non-bypassable architectural baseline upon which operational Zero Trust controls are subsequently applied.

Security Zones are positioned above the Landing Zone as a hard-enforced preventive mechanism within the Control Plane. They do not function as runtime PEPs, but as guardrails governing resource creation and modification. Any operation violating defined security principles—such as unintended public exposure, non-compliant encryption, or weak configuration—is blocked ex-ante by the OCI Control Plane. It is critical to clarify that Cloud Guard is a prerequisite for the use of Security Zones. Security Zone recipes are defined and maintained through Cloud Guard, which provides the policy engine, continuous posture evaluation, and alignment with OCI security best practices.

Cloud Guard therefore operates as a central detection and posture management service, transversal to both Control Plane and Data Plane. It is not a direct PEP; rather, it acts as a continuous security decision and analysis layer that evaluates configurations, audit events, network telemetry, and service signals, generating problems and automated or manual responses. Cloud Guard does not replace IAM, ZPR, NSGs, or WAF; instead, it observes,

validates, and reinforces them, providing continuous evidence that Zero Trust controls remain effective over time.

OCI Threat Intelligence, introduced at this stage of the model, functions as a contextual risk intelligence layer rather than a direct enforcement mechanism. It feeds WAF, Network Firewall, Cloud Guard, and other security services with indicators of compromise, IP reputation data, malicious domains, and global attack signals. Within the overall architecture, Threat Intelligence operates as a horizontal information layer that enhances the effectiveness of existing PEPs at Layers 7 and 3/4, as well as detection mechanisms, without altering authentication or authorization flows. Conceptually, while ZPR and IAM determine “who is permitted to communicate with whom,” Threat Intelligence contributes to assessing “whether that traffic or source is inherently suspicious,” thereby improving the quality of security decisions and corrective actions.

In summary, Landing Zones and Security Zones ensure that the architecture is secure by construction and remains compliant by design; Cloud Guard provides continuous visibility and operational assurance; and Threat Intelligence enriches the system with global risk awareness. These elements do not modify the existing enforcement diagrams, but constitute their structural foundation and operational nervous system, rendering the OCI Zero Trust model comprehensive, coherent, and sustainable within regulated enterprise environments.

Transversal Security and Governance Controls (Landing Zones, Identity Domain Perimeters, IAM Conditions, Network Enforcement, Posture Management, and Threat Intelligence)

STRATO TRASVERSALE + DATA PLANE — GOVERNANCE · PREVENZIONE · DETECTION · ENFORCEMENT

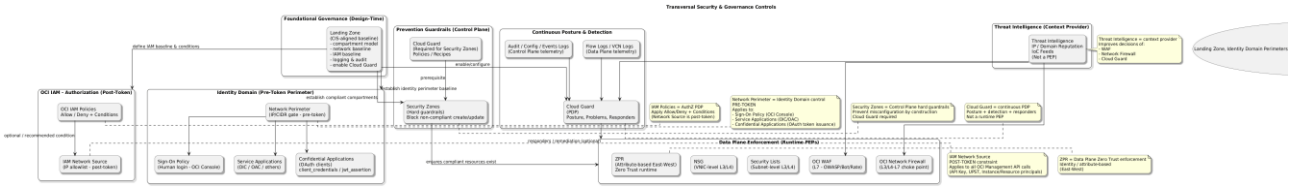
Componente OCI	Livello architetturale	Plane di riferimento	Ruolo Zero Trust	PDP / PEP	Dipendenze obbligatorie	Integrazione con altri controlli
Landing Zone	Fondazionale (design-time)	Trasversale (Control + Data Plane)	Governance by-construction: compartment model, network baseline, IAM baseline, logging, guardrail	**PDP (design)**	—	Abilita/standardizza IAM, Network Sources, Cloud Guard, Security Zones, logging
Security Zones	Guardrail hard-enforced	**Control Plane**	Prevenzione ex-ante: blocca create/update non conformi	**PEP (Control Plane)**	**Cloud Guard obbligatorio**	Impone ricette su risorse (esposizione pubblica, cifratura, ecc.)
Cloud Guard	CSPM/Threat detection	Control + Data Plane (osservazione)	Posture + detection continua; problems + responder	**PDP**	Abilitazione tenancy/compartment	Consuma Audit/Config/Logs; guida remediation; base per Security Zones
Threat Intelligence	Contesto rischio globale	Trasversale (input)	Feed reputazione/IP/IoC per aumentare efficacia dei controlli	**Input PDP**	—	Alimenta WAF, Network Firewall, Cloud Guard
Network Perimeter (Identity Domain)	Perimetro pre-token	**Identity Domain**	Vincolo IP/CIDR su **login umano** e/o **token issuance** (service/confidential apps)	**PEP (IdP edge)**	Identity Domain	Complementare a IAM Network Source (che è post-token)
Sign-On Policy (Identity Domain)	Login policy (umano)	Identity Domain	MFA/condizioni per login umano (OCI Console)	**PEP (Sign-In)**	Identity Domain	Può usare Network Perimeter per restringere sign-in
Confidential / Service Application (Identity Domain)	OAuth client/app policy	Identity Domain	Controlla **token issuance** (client_credentials, jwt_assertion, ecc.)	**PEP (Token Endpoint)**	Identity Domain	Può usare Network Perimeter (client IP restriction)
OCI IAM (Policies + Deny + Conditions)	Autorizzazione	**Control Plane**	Decisione allow/deny su operazioni OCI	**PDP**	—	Applica least privilege; condizioni; integra Network Sources
IAM Network Source	Condizione post-token	**Control Plane**	Vincolo IP/CIDR sulle chiamate alle OCI APIs (post-token)	**PDP/PEP**	—	Applicabile ovunque AuthZ = IAM (API Key, UPST, principals)
NSG	Micro-segmentation tradizionale	**Data Plane (L3/L4)**	Firewall stateful per VNIC / group	**PEP (VNIC)**	VCN	Complementare a ZPR; tipico per baseline ingress/egress
Security Lists (SL)	Segmentazione subnet	**Data Plane (L3/L4)**	Firewall subnet-wide	**PEP (Subnet)**	VCN	Baseline coarse; spesso "guardrail" rete legacy
ZPR	Zero Trust runtime	**Data Plane (L3/L4)**	Identity/attribute-based segmentation	**PEP (fabric)**	Security attributes	Micro-segmentation intent-based; supera IP-centric
OCI WAF	Enforcement applicativo	**Data Plane (L7)**	OWASP/bot/rate/IP reputation	**PEP (L7)**	—	Usa Threat Intelligence; protegge LB/API endpoints
OCI Network Firewall	Enforcement L3/L4–L7	**Data Plane**	IDS/IPS/egress/ingress control	**PEP**	—	Usa Threat Intelligence; controllo choke-point

CHIAVE DI LETTURA (DA NON CONFONDERE)

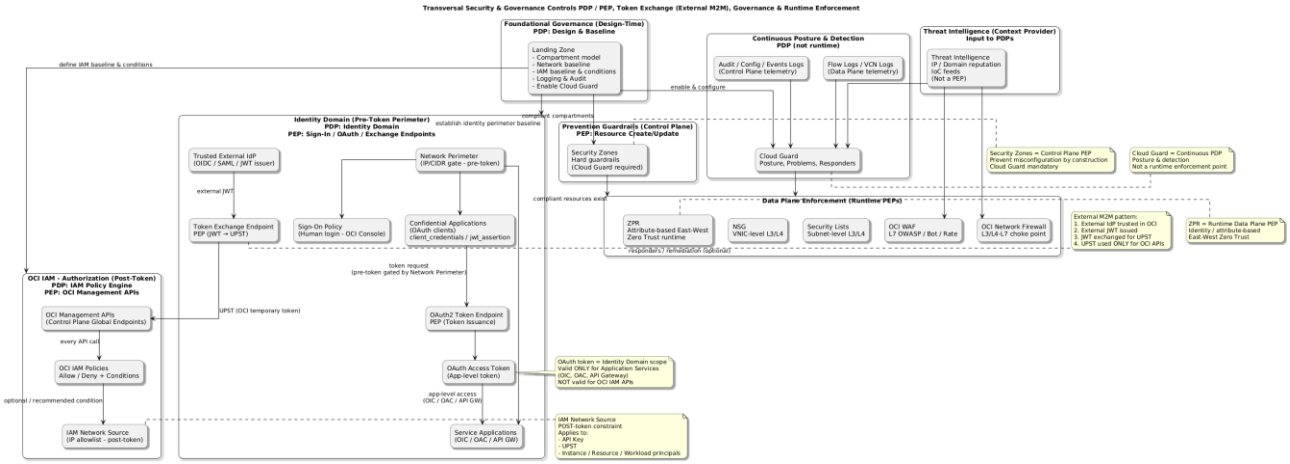
Security Zones	Enforcement **preventivo** su API di creazione/modifica risorse
Cloud Guard	Detection continua + risposta (condizione necessaria per Security Zones)
Threat Intelligence	**Non decide, non blocca**: fornisce contesto ai PEP
Landing Zone	Architettura "by construction", non controllo runtime
ZPR / WAF / Firewall	Enforcement **runtime** (Data Plane)

POSIZIONAMENTO NEL MODELLO ZERO TRUST OCI

Before runtime	Landing Zone, Security Zones
During runtime (decision)	IAM, ZPR
During runtime (enforcement)	ZPR, WAF, Network Firewall
After / Continuous	Cloud Guard
Context provider	Threat Intelligence



Transversal Security & Governance Controls (Landing Zone, Identity Domain Perimeters, IAM Conditions, Network Enforcement, Posture & Threat Intelligence): Final Diagram



Architectural Synthesis Matrix – OCI Zero Trust Access Model (Authentication, Authorization, Perimeters, and Runtime Enforcement)

Scenario di Accesso	Identità & AuthN (PDP)	Token / Credenziale	Perimetro PRE-token (PEP)	AuthZ POST-token (PDP)	Perimetro POST-token (PEP)	Data Plane (PEP runtime)	Nota architetturale corretta
Umano – OCI Console / CLI	Identity Domain (IdP federato)	Session token utente	**Network Perimeter** su Sign-On Policy	OCI IAM Policies	**IAM Network Source** (condizione)	NSG / SL / ZPR (solo su risorse)	Login è **pre-token IdP**; API call sempre valutate da IAM
Umano – CLI/SDK (no Console)	OCI IAM	API Key (request signing)	—	OCI IAM Policies	**IAM Network Source**	—	AuthN ≠ OAuth; è signing crittografico
M2M esterno – semplice	OCI IAM	API Key	—	OCI IAM Policies	**IAM Network Source**	—	Caso legacy; chiavi statiche
M2M esterno – Zero Trust	IdP esterno → Identity Domain	JWT → **UPST (Token Exchange)**	**Network Perimeter** su Token Exchange	OCI IAM Policies	**IAM Network Source**	—	JWT esterno **non** vale in OCI; serve exchange
M2M esterno – Broker	Identity Domain + OCI IAM	OAuth token → Resource Principal	**Network Perimeter** su OAuth	OCI IAM Policies (RP)	**IAM Network Source**	ZPR / NSG	Pattern raccomandato: esterno non tocca OCI APIs
API Gateway (OAuth)	Identity Domain	OAuth Access Token	**Network Perimeter**	Service authorization	—	—	Token valido **solo** per App Services
OIC / OAC / App Services	Identity Domain	OAuth Access Token	**Network Perimeter**	App roles / grants	—	—	**Mai** IAM Policies
Compute VM	OCI IAM	Instance Principal	—	OCI IAM Policies	**IAM Network Source**	NSG / ZPR	Zero chiavi statiche
OKE Pod	OCI IAM	Workload Identity Token	—	OCI IAM Policies	**IAM Network Source**	**ZPR (East-West)**	Identità legata al Pod
OCI Function	OCI IAM	Resource Principal Token	—	OCI IAM Policies	**IAM Network Source**	ZPR	Usata come broker o automation
Data Plane tra servizi	—	—	—	—	—	**ZPR**	ZPR governa *risorse*, non API

Zero Trust Packet Routing (ZPR) within the Context of the OCI Zero Trust Architecture (ZTA)

Intent-Based Data Plane Enforcement as the Culmination of OCI's Multi-Perimeter Security Model

Within the Oracle Cloud Infrastructure Zero Trust Architecture, Zero Trust Packet Routing (ZPR) represents the runtime enforcement layer of the data plane that completes and operationalizes the end-to-end Zero Trust strategy, without overlapping with or replacing identity, governance, and authorization controls in the control plane. In alignment with the principles defined in NIST SP 800-207, OCI clearly separates Authentication, Authorization, Policy Decision, and Enforcement, distributing these responsibilities across coordinated architectural layers. In this model, ZPR does not govern access to management APIs nor token issuance; instead, it operates exclusively on resource-to-resource communication, applying deterministic and continuous control over east–west network flows, even when valid identities or properly issued tokens are present.

The distinctive value of ZPR lies in its adoption of an Attribute-Based Access Control (ABAC) model applied to networking. OCI resources are annotated with security attributes, organized within logical namespaces, and ZPR policies express security intent in terms of permitted relationships between classes of resources rather than IP addresses, subnets, or ports. This approach fully decouples security semantics from network topology, reducing operational error, rule complexity, and the structural fragility typical of IP-centric models. Enforcement occurs at the fabric level as a runtime Policy Enforcement Point (PEP), and any traffic flow not explicitly authorized is denied, effectively implementing a default-deny principle within the data plane.

ZPR is therefore positioned above traditional micro-segmentation mechanisms such as Security Lists and Network Security Groups (NSGs), which remain essential as baseline Layer 3/Layer 4 controls but are insufficient in isolation within dynamic and distributed architectures. The combined model of NSG/Security Lists plus ZPR establishes layered defense: the former constrains exposure at the network boundary level, while the latter governs actual application-level relationships among workloads. This model proves particularly effective in complex scenarios involving Compute instances, Oracle Kubernetes Engine (OKE), Load Balancers, OCI Functions, and PaaS services, where network boundaries evolve frequently but security intent remains stable.

Within the broader OCI Zero Trust Architecture, ZPR functions as the final enforcement layer in a multi-perimeter chain that includes:

- pre-token controls at the Identity Domain level (Network Perimeters and Sign-On Policies governing login and token issuance for users and applications);
- post-token controls within the control plane (IAM Allow and Deny Policies, policy conditions, Network Sources, and Deny precedence governing Management APIs);
- preventive governance mechanisms (Landing Zones and Security Zones, with Cloud Guard as an operational prerequisite);
- continuous posture management and detection (Cloud Guard, Audit Logs, and Flow Logs).

Even in scenarios external to OCI—such as on-premises environments, multicloud integrations, or machine-to-machine contexts—where initial access may occur through federation, OAuth2, or JWT token exchange toward temporary OCI tokens, ZPR remains the final enforcement point within the data plane once internal OCI resources are engaged. In this sense, ZPR is neither a firewall nor a proxy, but a formal resource-relationship control mechanism that transforms the Zero Trust model from a theoretical principle into a verifiable operating system of security—resilient to change and suitable for regulated enterprise environments.

Intent-Based Data Plane Enforcement as the Culmination of OCI's Multi-Perimeter Security Model

Tabella finale 1 — Posizionamento di ZPR nella ZTA OCI (PDP / PEP)

Livello	Dominio	Controllo	Ruolo	PDP / PEP
Identity (pre-token)	Identity Domain	Network Perimeter, Sign-On Policy	Restringe login e token issuance	**PEP (IdP edge)**
Authorization (post-token)	Control Plane	IAM Policies, Deny, Conditions, Network Source	Decide allow/deny su OCI APIs	**PDP (IAM)**
Governance ex-ante	Control Plane	Landing Zone, Security Zones	Previene configurazioni non conformi	**PEP (design-time)**
Detection & posture	Control + Data Plane	Cloud Guard	Valuta rischio e posture	**PDP**
Runtime enforcement	**Data Plane**	**ZPR**	**Blocca/consente flussi tra risorse**	**PEP (fabric)**

Tabella finale 2 — ZPR vs controlli di rete tradizionali

Caratteristica	Security List / NSG	ZPR
Modello	IP-centric (CIDR, porte)	Attribute-centric (ABAC)
Livello	L3/L4	Data Plane intent-based
Dinamicità	Limitata	Elevata
Resilienza al drift	Bassa	Alta
Semantica applicativa	Assente	Esplicita
Ruolo in ZTA	Baseline	Culmine runtime

Tabella finale 3 — Scenari e risorse supportate da OCI ZPR (Security Attributes & Intent-Based Data-Plane Enforcement) docs.oracle.com

3A) Risorse OCI a cui si possono assegnare Security Attributes (ZPR "Protected Resources") docs.oracle.com

Servizio OCI	Resource types (come da doc ZPR)	Interpretazione operativa (endpoint L3/L4 su cui ZPR può "matchare" policy)
Compute	`instance`, `instance-configurations`	VM/BM e template di configurazione; enforcement runtime sui flussi verso/da le **VNIC** associate. docs.oracle.com
Database	`autonomous-databases`, `cloud-autonomous-vmclusters`, `cloud-vmclusters`, `databases`, `db-systems`, `exadb-vm-clusters`	Data endpoints (ADB private endpoint / DBaaS / ExaCS) come target "data plane"; ZPR governa chi può connettersi a chi (L4), indipendente da subnet design. docs.oracle.com
Database Tools	`private endpoints`	Endpoint privati "tooling" (es. accesso privato a servizi DB Tools); trattabili come endpoint di rete in policy. docs.oracle.com
DevOps	`private endpoints`	Endpoint privati per DevOps; stessi principi: label → intent policy → enforcement data plane. docs.oracle.com
File Storage	`mount targets`	Target NFS come endpoint; ZPR può vincolare chi può montare/parlare con i mount target a livello L4. docs.oracle.com
Functions	`applications`	**Non** "la singola function": la risorsa ZPR-taggabile è l'**Application**; i flussi generati dalle funzioni ereditano l'intent applicativo. docs.oracle.com +1
GoldenGate	`deployments`, `connections`	Replication/data-movement endpoints: controllo "chi parla con chi" tra componenti di replica, evitando "flat network trust". docs.oracle.com
Load Balancer	`load balancers`	LB come endpoint (frontend/backends) taggabile: policy intent-based tra LB e target, oltre NSG/SL. docs.oracle.com +2
MySQL HeatWave	`db-system`, `replica`	Endpoint MySQL/replica; segmentazione e least-privilege su flussi applicativi verso DB. docs.oracle.com
Networking	`vcns`, `vnics`, `PrivateEndpoint`	ZPR può usare **VNIC** (fondamentale per workload endpoints) e oggetti "private endpoint" come primitive di policy; VCN compare come "scope" logico di intent. docs.oracle.com
Private Service Access (PSA)	`endpoints`	Endpoint PSA come target/peer in policy (tipicamente per accessi privati a servizi); si modella come endpoint data-plane. docs.oracle.com

3B) Scenari supportati da ZPR (pattern corretti, cosa copre e cosa NON copre) docs.oracle.com

Scenario (sorgente → destinazione)	Applicabilità ZPR	Risorse tipiche (taggabili)	Nota "da architettura Zero Trust"
Compute ↔ Compute (east-west)	**Sì**	Compute `instance` / Networking `vnic`	Segmentazione **intra-subnet** e **inter-subnet**: l'intento non dipende dal CIDR; resta comunque "layered" con NSG/SL. docs.oracle.com
Compute → DB / DBaaS / ExaCS / ADB	**Sì**	Database (`autonomous-databases`, `db-systems`, `exadb-vm-clusters`, ...)	Modello "app:trusted → data:sensitive"; enforcement L4 su ogni tentativo di connessione, indipendente da drift/misconfig di rete. docs.oracle.com
OKE Pod ↔ Pod / Pod → servizi in VCN	**Sì (tramite endpoint di rete)**	Networking `vnic` (VNIC dei worker/pod networking), target DB/LB/PrivateEndpoint	In pratica ZPR "vede" e governa i flussi sui **VNIC/endpoint**; non è RBAC Kubernetes e non sostituisce NetworkPolicy/NSG, ma aggiunge intent-segmentation coerente cross-workload. docs.oracle.com
Load Balancer ↔ Backend	**Sì**	Load Balancer `load balancers` + backend endpoints (VNIC/DB/PSA)	Caso d'uso chiave: vincolare quali backends un LB può raggiungere (e viceversa) con label su LB e target. docs.public.cont... +2
Functions (Application) → servizi OCI in VCN	**Sì**	Functions `applications` + target (DB/LB/PrivateEndpoint/PSA/...)	Il controllo è sull'**application flow** (security attributes sull'Application); utile per "serverless least privilege network" oltre alle IAM policy. docs.oracle.com +1
GoldenGate deployment/connection → target DB/endpoint	**Sì**	GoldenGate `deployments`, `connections`	Segmentazione dei canali di replica/data-movement: impedisce "replica-to-anywhere" per misconfig. docs.oracle.com
File Storage mount target ↔ client workloads	**Sì**	File Storage `mount targets` + client VNIC	Applicazione del principio "solo workload autorizzati possono montare NFS", senza dipendere dal posizionamento subnet. docs.oracle.com
DevOps / DB Tools private endpoints ↔ workloads	**Sì**	`private endpoints` (DevOps/DB Tools) + VNIC/target	Controllo "tooling plane" nel data path privato: consente di ridurre superfici di movim[No Title] laterale. docs.oracle.com
MySQL HeatWave DB system/replica ↔ apps	**Sì**	MySQL HeatWave `db-system`, `replica`	Pattern "app tier → db tier" con attributi; riduce blast radius tra ambienti (stage/prod) senza duplicare subnet. docs.oracle.com
Chiamate a OCI Management APIs (control plane)	**No (ZPR non è per questo)**	—	Qui governa **IAM** (Allow/Deny + condizioni, incluse Network Sources) e, lato sign-in/token issuance, Identity Domain/Perimeters. ZPR resta data-plane. docs.oracle.com
Login console / SSO / OAuth2 token issuance (Identity Domain)	**No (ZPR non è il PEP)**	—	Qui il PEP/PDP è l'**Identity Domain** (Sign-On Policy, Network Perimeter, Confidential App IP restriction). ZPR non emette né valida token. docs.oracle.com

Zero Trust Packet Routing (ZPR) represents the most advanced enforcement layer of the Oracle Cloud Infrastructure Zero Trust Architecture (ZTA), translating the principles defined in NIST SP 800-207 into a distributed, runtime, identity-centric control mechanism fully decoupled from underlying network topology. Unlike traditional security controls based on IP addresses, subnets, and static rules, ZPR introduces an intent-based policy model grounded in Attribute-Based Access Control (ABAC), in which communication decisions are made exclusively on the basis of logical resource identity and security context.

From an architectural perspective, ZPR implements a centralized Policy Decision Point (PDP) within the OCI control plane and a distributed set of Policy Enforcement Points (PEPs) operating at the VNIC level, evaluated after traditional Layer 3/Layer 4 enforcement provided by Security Lists and Network Security Groups (NSGs). This model enables a clear separation between network reachability—managed by mechanisms such as VCN routing, Private Service Access, Dynamic Routing Gateway (DRG), and peering—and security reachability, thereby eliminating structural dependency between security posture and CIDR design. As a result, common configuration errors typical of complex multi-tier and multi-VCN environments are substantially reduced.

The ZPR policy language (ZPL) enables declarative and human-readable expression of security intent. For example, it can authorize traffic from app:frontend to db:finance independently of subnet placement, network path, or the presence of Private Service Access. Security attributes, organized into logical namespaces, become the true security identity of OCI resources—including Compute instances, Databases, Load Balancers, OCI Functions, and Oracle Kubernetes Engine (OKE) Pods—thereby enabling native east–west micro-segmentation that remains scalable and consistent within dynamic environments.

Within the OCI Zero Trust Architecture, ZPR does not replace existing security controls but overlays and cooperates with them. IAM Policies, Deny Policies, and Network Sources govern access to OCI Management APIs within the control plane. Identity Domain controls, Network Perimeters, and OAuth2 flows regulate authentication and token issuance for users and applications. Security Zones and Cloud Guard provide security-by-construction and posture management capabilities. NSGs, Security Lists, Web Application Firewall (WAF), and Network Firewall continue to provide perimeter and north–south enforcement. ZPR operates as the final decision layer within the data plane, ensuring that even when routing is technically feasible, communication is permitted only if explicitly authorized by declared security intent. This dramatically reduces attack surface, prevents data exfiltration, and renders security independent from architectural evolution.

In the context of Private Service Access (PSA), ZPR introduces a fundamental shift. PSA provides private connectivity to OCI services, but ZPR governs which resources are actually authorized to communicate with those services. This transforms PSA from a connectivity mechanism into an attribute-based Zero Trust perimeter. Even in environments involving DRG, FastConnect, or complex peering configurations, each traffic flow is evaluated locally at the VNIC level based on the security identity of both source and destination resources.

In summary, ZPR constitutes the most operationally pure realization of the Zero Trust paradigm within OCI. It shifts control from the “where” of network topology to the “who” and “why” of identity and declared intent, making security deterministic, verifiable, and resilient. Within the OCI Zero Trust Architecture, ZPR represents the culminating component where governance, identity, and data plane enforcement converge into a coherent, formally structured, and audit-ready security model.

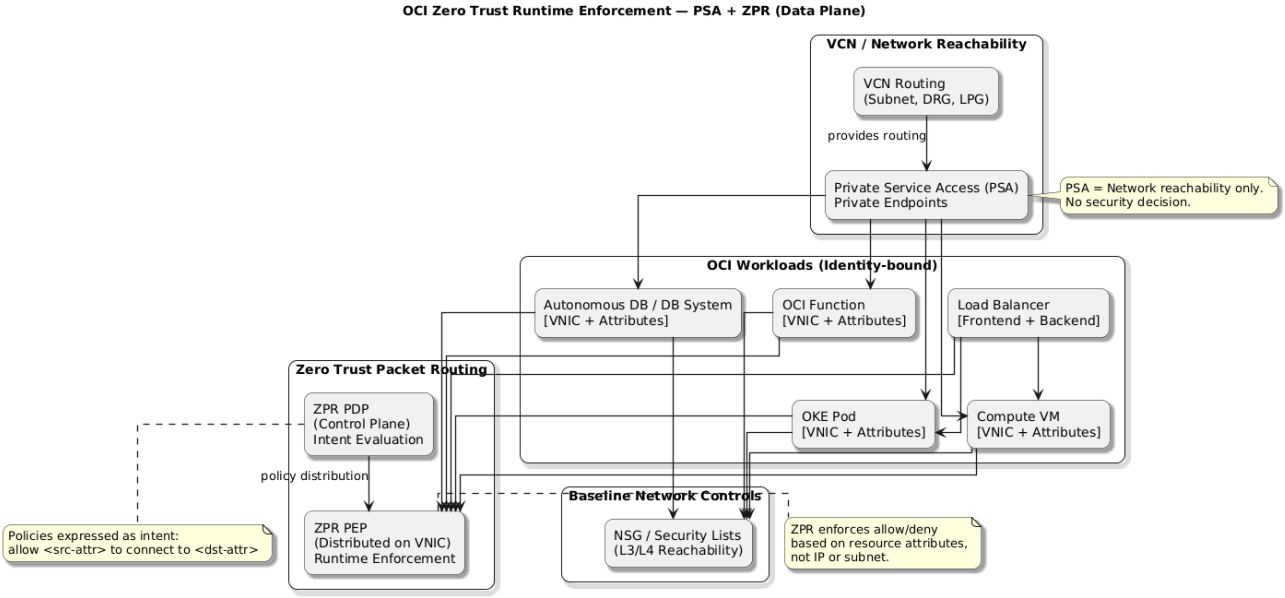


Tabella comparativa finale — ZPR vs (NSG/SL/WAF/Network Firewall/Security Zones/Cloud Guard/IAM Policies+Network Sources/Network Perimeter/Landing Zone/Threat Intelligence)

Dimensione	ZPR	NSG	Security Lists	WAF	OCI Network Firewall	IAM Policies + Deny + Conditions + Network Sources	Network Perimeter (Identity Domain)	Security Zones	Cloud Guard	Landing Zone	Threat Intelligence
Piano	**Data Plane**	Data Plane	Data Plane	Data Plane	Data Plane	**Control Plane**	**Identity Plane (pre-token)**	Control Plane	Control+Data (osservazione)	Design-time	Trasversale (input)
Strato	**L3/L4 intent-based**	L3/L4 tuple	L3/L4 tuple	**L7 HTTP(S)**	L3–L7 choke-point	Autorizzazione API/azioni	Sign-in + token issuance	Guardrail create/update	CSPM/Detection/Response	Baseline architetturale	Reputation/IoC context
Scopo primario	**Micro-segmentazione east-west "by intent"**	Segmentazione per VNIC/Group	Segmentazione per subnet	Protezione web/API (OWASP/bot/rate)	Ispezione/IPS/egress/ingress	**Decidere "chi può fare cosa" su OCI APIs**	**Decidere "da dove si può autenticare/ottenere token"**	Prevenire misconfig (hard)	Rilevare/rimediate posture & threats	Standardizzare governance	Arricchire decisioni
Modello	**ABAC (security attributes) + ZPL**	IP/CIDR/port	IP/CIDR/port	HTTP semantics	Signatures/IPS/rules	RBAC/ABAC (policy engine)	CIDR/IP gate "pre-token"	Ricette/guardrail	Finding/Responder	Blueprint	Feed reputazionale
PDP	**ZPR PDP** (control plane)	—	—	WAF policy engine	NFW policy engine	**OCI IAM policy engine**	Identity Domain policy	Security Zone engine	Cloud Guard engine	Standard/blueprint	N/A
PEP	**Distributed on VNIC (runtime)**	VNIC	Subnet	WAF edge	Firewall appliance	Management API endpoints	IdP sign-in/token endpoints	Create/Update enforcement	Responders (opzionali)	Provisioning guardrails	Fornisce segnali
Pre-token / Post-token	**Post-token (data plane)**	Post-token	Post-token	Post-token	Post-token	**Post-token**	**Pre-token**	N/A	N/A	N/A	N/A
Cosa protegge	**Flussi tra risorse**	Flussi L3/L4	Flussi L3/L4	App web/API	Ingress/egress chokepoint	**Operazioni su risorse OCI (API)**	Login/OAuth issuance	Configurazioni	Posture/eventi	Intero tenancy baseline	WAF/NFW/CG context
East–West	**Eccellente**	Buono	Medio	N/A	Medio (se hairpin)	N/A	N/A	Indiretto	Indiretto	Indiretto	Indiretto
North–South	Limitato (non edge)	Buono	Buono	**Eccellente**	**Eccellente**	N/A	N/A	Indiretto	Indiretto	Indiretto	Supporto
Control Plane (API)	**No**	No	No	No	No	**Sì (core)**	No	Sì (guardrail)	Sì (detection)	Sì (baseline)	No
Identità-centric	**Sì (attributes)**	No	No	Parziale	Parziale	**Sì (principal/user/service)**	**Sì (IdP)**	No	Parziale	No	No
Tipico "errore umano" mitigato	Regole IP esplose / drift	Aperture troppo ampie	Subnet flat trust	OWASP gap	misconfig egress/IPS	Privilegi eccessivi	Token issuance da IP non trusted	risorse non compliant	mancata visibilità	inconsistenza baseline	IP malevoli non bloccati
Come si combina con ZPR	—	**Baseline L3/L4**	Baseline legacy	Complementare per L7	Complementare per chokepoint	Complementare (API governance)	Complementare (pre-token)	Complementare (prevenzione)	Complementare (detection)	Complementare (design)	Alimenta WAF/NFW/CG

Integrated Architectural Interpretation of OCI Security Controls (ZPR as Runtime Enforcer within the Multi-Perimeter Zero Trust Model)

1. **ZPR is the only OCI control that implements east–west micro-segmentation through intent-based ABAC within the data plane.**
   It does not depend on CIDR structures and does not require "modeling security" within network topology. Security semantics are decoupled from IP design and expressed purely through resource attributes and declared intent.
2. **Network Security Groups (NSGs) and Security Lists remain indispensable Layer 3/Layer 4 baselines.**
   They reduce exposure surface and define mechanical boundaries (ports and protocols), while ZPR governs security intent between logical classes of resources.
3. **IAM Policies, Deny Policies, Conditions, and Network Sources constitute the Policy Decision Point (PDP) of the control plane.**
   They determine every operation executed against OCI Management APIs. ZPR does not replace IAM, as it does not govern API access.
4. **Network Perimeter (Identity Domain) is a pre-token control.**
   It constrains sign-on and token issuance (OAuth2/Identity Provider flows) and conceptually acts as the gate before any session or token exists.
5. **Security Zones (with Cloud Guard as prerequisite) provide hard guardrails on create and update operations.**
   They prevent entire classes of misconfigurations before reaching runtime, enforcing security by construction.
6. **Cloud Guard delivers continuous posture management and detection.**
   It operates as an observational decision layer with responder capabilities. It is not a runtime PEP, but feeds governance and remediation processes.
7. **Web Application Firewall (WAF) and Network Firewall are specialized PEPs for north–south enforcement.**
   They operate at Layer 7 and choke points respectively, integrate with Threat Intelligence and edge security paths, and complement—but do not address—the east–west intent-based enforcement domain native to ZPR.
8. **Landing Zone represents the architectural root of coherence.**
   It defines the compartment model, baseline logging, baseline IAM structure, and network design. It reduces variability and enables systematic adoption of ZPR and perimeter controls.

This integrated reading clarifies that within the OCI Zero Trust multi-perimeter model, ZPR functions as the definitive runtime enforcer of data plane intent. Governance, identity, and perimeter controls establish preconditions and decision authority, while ZPR ensures that communication between resources is permitted exclusively when explicitly authorized by declared security intent.

Prescriptive Matrix — Access Scenario → Mandatory Security Tool Chain (OCI Zero Trust Architecture)

Purpose:
To provide a deterministic and verifiable mapping between operational access scenarios and the minimum required set of OCI security controls, fully aligned with the Zero Trust Architecture (NIST SP 800-207) and the OCI multi-perimeter security model.

Scenario → Tool Chain

Scenario di Accesso	Piano	Tool Chain di Sicurezza OBBLIGATORIA	Razionale Zero Trust (per audit)
Umano – OCI Console (SSO)	Identity / Control	Identity Domain + Sign-On Policy + **Network Perimeter** + IAM Policies + (opz.) IAM Deny	Pre-token restriction + least privilege su API
Umano – OCI CLI / SDK	Control Plane	IAM User/Federated User + API Signing + IAM Policies + **IAM Network Source**	API access consentito solo da egress noti
M2M On-Prem (legacy)	Control Plane	API Key + IAM Policies + **IAM Network Source**	Caso ammesso ma non raccomandato (chiavi statiche)
M2M On-Prem (Zero Trust)	Identity → Control	External IdP + **JWT → UPST Token Exchange** + IAM Policies + **IAM Network Source**	Eliminazione API key, token temporanei, controllo post-token
M2M On-Prem (Broker pattern)	Identity → Data	Network Perimeter + OAuth2 (Confidential App) + API Gateway + **OCI Function (Resource Principal)** + IAM Policies + ZPR	Trust boundary netto: esterno non chiama OCI APIs
Application OAuth (OIC / OAC / App Services)	Identity	Identity Domain + Confidential App + **Network Perimeter** + App Roles	OAuth valido solo per Application Services
Compute VM → OCI APIs	Control Plane	**Instance Principal** + IAM Policies + **IAM Network Source**	Nessuna credenziale statica
OCI Function → OCI APIs	Control Plane	**Resource Principal** + IAM Policies + **IAM Network Source**	Serverless least privilege
OKE Pod → OCI APIs	Control Plane	**Workload Identity** + IAM Policies + **IAM Network Source**	Identity per Pod, non per nodo
Compute / Pod / Function → DB (ADB / DBaaS / ExaCS)	Data Plane	NSG + **ZPR (ABAC)** + (opz.) Security Zone	Solo flussi esplicitamente autorizzati
Load Balancer → Backend	Data Plane	NSG + **ZPR (LB attributes)** + WAF (se HTTP)	Intent-based backend reachability
East–West intra-VCN	Data Plane	NSG (baseline) + **ZPR**	Micro-segmentazione deterministica
East–West tra VCN (peering/DRG)	Data Plane	Routing/PSA + NSG + **ZPR**	Reachability ≠ authorization
Accesso a servizi via PSA (Private Service Access)	Data Plane	PSA + NSG + **ZPR (endpoint attributes)**	PSA fornisce tubi, ZPR decide
Provisioning risorse critiche	Design-time	**Landing Zone + Security Zones (Cloud Guard prereq.)**	Prevenzione by-construction
Monitoraggio continuo sicurezza	Trasversale	**Cloud Guard + Audit + Flow Logs + Threat Intelligence**	Detection, posture, risposta

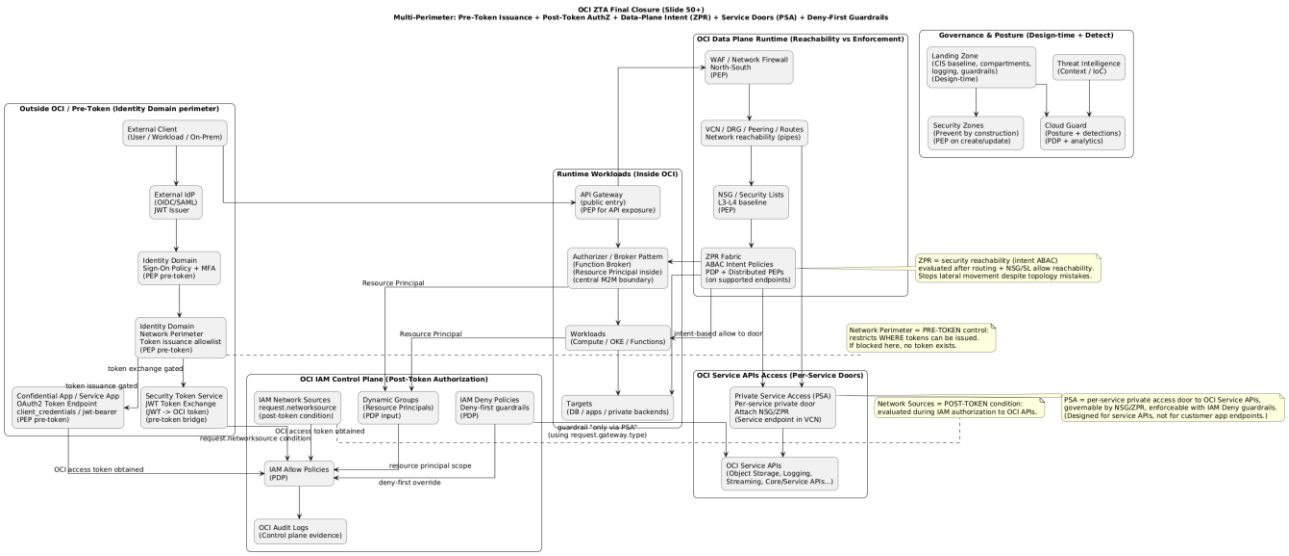
Reading Legend (Essential for Audit Purposes)

- **Network Perimeter** → Pre-token control (Identity Domain level)
- **IAM Network Source** → Post-token control (OCI IAM, Management APIs)
- **ZPR** → Runtime enforcement on the data plane, identity/attribute-based
- **Security Zones** → Ex-ante guardrail (create/update operations)
- **Cloud Guard** → Detection and posture management (not a runtime enforcement mechanism)
- **NSG / Security Lists** → Layer 3/Layer 4 baseline controls, not sufficient in isolation

Golden Rule of Interpretation

If a given scenario does not explicitly map to a defined security tool chain as described above, the scenario cannot be considered Zero Trust compliant.

Pre-Token Issuance + Post-Token AuthZ + Data-Plane Intent (ZPR) + Service Doors (PSA) + Deny-First Guardrails



Prescriptive OCI Zero Trust Architecture Matrix — Scenario → Mandatory Control Chain (Pre-Token / Post-Token / Data-Plane / Governance / Evidence)

Scenario (boundary)	Plane dominante	AuthN (CHI)	Token & Issuance (PRE-TOKEN: Identity Domain)	Post-Token AuthZ (CONTROL PLANE: IAM PDP)	Data-Plane Enforcement (PEP runtime)	Service APIs access (doors)	Governance / Guardrails	Evidence (audit-ready)	Failure mode che neutralizzi
S1. Human Admin → OCI Console/CLI (internet/VPN)	Control plane	User federato (IdP)	**Sign-On Policy + MFA + Network Perimeter** (blocca token issuance fuori rete fidata)	**IAM Allow + IAM Deny (deny-first) + Network Sources** (condizione post-token)	N/A	N/A	Landing Zone baseline + Security Zones (se abilitate) + Cloud Guard posture	OCI Audit (login, API calls), Cloud Guard findings	Credential theft + access da reti non approvate; delega eccessiva in tenancy
S2. External App (OIC/3rd party) → OCI Service APIs via OAuth2	Control plane	**Confidential App** (client)	**Network Perimeter** limita emissione token dal token endpoint	IAM Allow/Deny + Network Sources su operazioni API	N/A	**Prefer: PSA door** (se servizio supportato) + Deny "only via PSA"	Security Zones + Cloud Guard	Audit (token usage + API calls), policy decisions	API exposure da internet / credenziali valide usate da path non approvato
S3. External M2M (no static keys) → OCI APIs via JWT Token Exchange	Control plane	Workload esterno (IdP JWT)	**Network Perimeter** davanti al bridge di exchange; exchange produce token OCI	IAM Allow/Deny + Network Sources	N/A	Se API di servizio: PSA + Deny only-via-PSA	LZ + SZ + CG	Audit STS/exchange + OCI Audit	Rotazione identità esterna, riduzione rischio API keys; limita token issuance "fuori perimetro"
S4. Legacy External M2M → OCI APIs con API Signing Key (API Keys)	Control plane	API key (legacy)	(N/A: non c'è issuance) → **compensa** con Network Perimeter non applicabile	IAM Allow/Deny + **Network Sources obbligatorie** (stringi IP/range) + least privilege	N/A	Dove possibile: PSA + Deny only-via-PSA	SZ/CG + rotazione key + vault	OCI Audit + key rotation evidence	Furto key, utilizzo da internet; (scenario "da evitare", ma governabile)
S5. Internet Client → API Gateway → Private Backends	Data plane + control plane	End-user OIDC/JWT (app)	Per user/app token: **Sign-On/MFA** e/o **Network Perimeter** se vuoi vincolare issuance	IAM per governance/config del gateway + deny guardrail su risorse	**WAF/Network Firewall (N-S) + NSG/SL + ZPR** (E-W intent)	Se backend chiama servizi OCI: PSA + ZPR to PSA	SZ + CG + TI	WAF logs + APIGW logs + flow logs + ZPR decisions	Misconfig NSG/SL che espone DB; lateral movement dal tier pubblico
S6. On-Prem M2M → API Gateway → Function Authorizer → Token minting (app token)	Multi-plane	Workload esterno	Token issuance esterna: Network Perimeter lato IdD; oppure authorizer emette token applicativo	IAM per authorizer + deny guardrails; Network Sources per API admin	WAF/NFW + NSG/SL + ZPR per isolare authorizer e target	PSA se authorizer/backends usano service APIs	LZ/SZ/CG	APIGW/Function logs + audit IAM + flow	"Stolen credentials" mitigato: authorizer centralizza policy e limita blast radius
S7. Inside OCI Workload → OCI APIs (Resource Principal)	Control plane	**Resource Principal** (Functions/OKE/Compute)	N/A (principal nativo)	**Dynamic Group + Allow/Deny + Network Sources**	N/A	PSA per service APIs + Deny only-via-PSA	SZ/CG	OCI Audit (API calls), function logs	Evita secret zero; limita chiamate da subnet non autorizzate
S8. Inside OCI Workload → Workload (east-west microsegmentation)	Data plane	Identity = security attributes	N/A	N/A (non è IAM APIs)	**NSG/SL baseline + ZPR intent ABAC** (what-talks-to-what)	N/A	SZ/CG	VCN flow logs + ZPR policy/evaluation evidence	Lateral movement e "security drift" da cambi CIDR/topologia
S9. Inside OCI Workload → OCI Service APIs via SGW (broad private access)	Data + control plane	Resource principal / user	N/A	IAM Allow/Deny + Network Sources per API calls	NSG/SL (+ZPR se endpoint supportato)	**SGW = accesso "region-wide"** (meno granulare)	SZ/CG	Flow logs + Audit	Riduci public internet, ma rimane "ampio" (tutti i servizi del SGW)
S10. Inside OCI Workload → OCI Service APIs via PSA (fine-grained)	Data + control plane	Resource principal / user	N/A	IAM Allow/Deny + Network Sources	**ZPR/NSG su PSA** (door policy)	**PSA = per-service door + IAM Deny "only via PSA"**	SZ/CG	Audit + PSA metrics/path analysis + flow logs	Data exfiltration e accesso a servizi non approvati; credenziali rubate usate da path pubblico Blog di Oracle
S11. Hybrid: On-prem → OCI Service APIs privately (via VCN DNS→PSA)	Data plane	Workload on-prem	N/A (a seconda auth)	IAM allow/deny per le API invocate	NSG/ZPR su PSA + edge controls	PSA door	LZ/SZ/CG	Network evidence + Audit	"Service access" resta privato e vincolato a door; riduce leakage
S12. Human/App → Database endpoint (SQLNet/HTTPS app endpoint)	Data plane	User/app identity	(dipende: user federato o app)	IAM non governa il socket DB (governa gestione risorsa; non il TCP)	NSG/SL + ZPR (se endpoint supportato) + edge segmentation	PSA **non** è door per SQLNet; PSA è per **service APIs**	SZ/CG + DB controls	Flow logs + DB audit + ZPR evidence	Confusione "IAM ≠ data plane": qui serve microsegmentation runtime e controlli DB

ZPR Applicability Map — Security Attributes Coverage & Enforcement Surfaces

Superficie / risorsa	Si possono applicare Security Attributes per ZPR?	Esempio di intento (ZPL)	Perché è cruciale in ZTA
Workload VNIC (Compute)	Sì	`allow app:frontend to connect to db:backend on tcp/1521`	Micro-segmentazione east-west disaccoppiata da CIDR/topologia Blog di Oracle
OKE workloads (via networking del cluster)	Sì (se endpoint supportato dal modello ZPR)	`allow app:api to connect to svc:payments on tcp/443`	Lateral movement containment nel cluster senza esplosione NSG
Load Balancer / NLB endpoints (se supportati)	Sì (dove il servizio espone endpoint supportato)	`allow edge:lb to connect to app:backend on tcp/443`	Policy "what talks to what" a livello di tier ingress
OCI Functions (applications / endpoints supportati)	Sì (su superfici supportate dal servizio)	`allow app:broker to connect to svc:objectstorage on tcp/443`	Serverless con enforcement intent-based senza IP management Blog di Oracle
Database private endpoints / service endpoints supportati	Sì (se endpoint rientra tra quelli supportati)	`allow app:mid to connect to db:core on tcp/1521`	Zero trust east-west su tier dati
PSA endpoints (Service Doors)	**Sì**	`allow app:etl to connect to door:os on tcp/443`	È la combinazione più forte: "door privata per-servizio" + intent ABAC Blog di Oracle
OCI Management APIs (Control plane)	**No (non è ZPR)**	—	Qui governa IAM (Allow/Deny/Network Sources), non ZPR Blog di Oracle
Login / token issuance (pre-token)	**No (non è ZPR)**	—	Qui governa Identity Domain: Sign-On + Network Perimeter (issuance)

OCI Zero Trust Architecture: A Multi-Plane Enforcement Ontology

Oracle Cloud Infrastructure implements a comprehensive Zero Trust Architecture not through a single control, but through a rigorously layered system of logical, temporal, and functional perimeters that clearly separate identity, authorization, network reachability, and runtime enforcement. The defining shift in the OCI approach is the definitive abandonment of the assumption that security can be inferred from network topology or subnet ordering. Instead, every decision is based on verified identity, source context, and declared intent. In this model, the concept of "perimeter" is no longer geographic or CIDR-based; it is distributed across time and architectural planes, with controls acting before, during, and after credential issuance, and ultimately during live network execution.

The first foundational perimeter is the token issuance perimeter, which resides entirely within the Identity Domain and is conceptually external to OCI IAM. Sign-On Policies, multi-factor authentication, and particularly Network Perimeters operate before any OAuth2 or federated token is issued. This layer does not determine what an identity can do; it determines whether an identity is permitted to exist as an authenticated subject within the system. If a login or token issuance request originates from an unauthorized network context, no credential is issued and the flow is terminated before entering the IAM domain. This reflects a pure Zero Trust principle: what is not contextually legitimate must not even obtain a valid identity. Network Perimeter is therefore not an alternative to Network Sources, but a temporally prior and semantically stronger control, as it operates before the token itself exists.

Once a token has been issued, the system enters the second domain: authorization within the OCI control plane. Here, IAM functions as the central Policy Decision Point. Allow Policies define minimal capabilities according to least privilege, while IAM Deny Policies introduce an explicit deny-first model capable of enforcing tenancy-wide guardrails that cannot be bypassed by delegated administrators. At this stage, Network Sources assume their correct role: they do not block token issuance, but condition token usage during invocation of OCI APIs. Even a valid credential cannot be used if it originates from a non-approved network context. This layer is entirely control-plane oriented, governing OCI management and service APIs, and remains completely decoupled from Layer 3 and Layer 4 network flows. It defines who may create, modify, or invoke resources—not who may communicate with whom at runtime.

The third domain, and the one most frequently misunderstood in traditional architectures, is the runtime data plane. Routing, DRG, peering, Service Gateway, Network Security Groups, and Security Lists define only network reachability—that is, the existence of communication paths. These controls do not express application-level security intent and cannot protect against misconfiguration, architectural drift, or emergent complexity. Zero Trust Packet Routing intervenes precisely at this point as the final enforcement layer, transforming reachability into effective security. ZPR evaluates declared intent through security attributes and applies ABAC-based decisions directly to traffic flows, independently of CIDR, subnet, or topology. Even when routing is correct and an NSG rule is permissive, ZPR can block communication unless explicitly authorized by policy intent. This renders security resilient to human error and architectural evolution, as declared intent remains stable even when infrastructure changes.

A crucial dimension of OCI's Zero Trust maturity is the introduction of Private Service Access (PSA) as a concept distinct from both Service Gateway and application-level private endpoints. PSA is not a generic mechanism to privatize any PaaS endpoint, nor a substitute for database or

application endpoints such as ORDS. PSA represents a per-service private access door to OCI service APIs, created within a VCN, bound to a private IP address, and transparently integrated with DNS resolution. Its architectural value lies in its governance capability as a network surface: NSGs and ZPR can be applied to it, and IAM Deny Policies can enforce its mandatory usage by blocking alternative access paths. In this manner, even valid credentials cannot be used to exfiltrate data through public endpoints or unapproved routes. PSA, ZPR, and IAM Deny together form a triangular control model that unifies control plane, data plane, and governance into a coherent enforcement framework.

Governance completes the architecture as a transversal and persistent layer. Landing Zones establish structural baselines, compartmentalization, mandatory logging, and security integrations. Security Zones prevent non-compliant configurations by design, operating as enforcement points on create and update operations. Cloud Guard observes, correlates, and detects deviations or anomalous behavior, while Threat Intelligence enriches decisions with external risk context. This layer does not perform real-time forwarding or authorization decisions, but ensures that the system remains verifiable, auditable, and defensible over time.

The unavoidable conclusion is that OCI does not implement Zero Trust as a slogan or a single feature, but as a systemic architecture. Identity is validated before it exists; authorization is denied before it is granted; the network is treated as untrusted even when private; and service access is channeled through explicit, verifiable doors. ZPR does not replace IAM; PSA does not replace Service Gateway; Network Perimeter does not replace Network Sources. Each control operates within its proper architectural plane and temporal phase, as an explicit PDP or PEP. It is this rigorous separation of responsibilities—combined with the ability to compose these controls into prescriptive, audit-ready chains—that positions OCI's Zero Trust Architecture among the most advanced and formally coherent implementations available in enterprise cloud environments today.

Tabella finale — OCI Zero Trust Architecture
Pre-Token vs Post-Token Controls, Principals, PDP/PEP, Planes

Scenario	Origine identità	Meccanismo AuthN	Pre-Token Controls (PDP/PEP)	Tipo di Principal in OCI	Post-Token AuthZ (Control Plane PDP)	Data Plane Enforcement (PEP)	Governance / Guardrails	Note di correttezza ZTA
Utente umano → OCI Console / OCI CLI (browser-based auth)	External IdP federato	OAuth2 / OIDC via Confidential App	Network Perimeter + Sign-On Policy + MFA (Identity Domain, **pre-token**)	OCI User Principal	IAM Allow + IAM Deny + Network Sources	N/A	Landing Zone, Security Zones, Cloud Guard	Network Perimeter protegge **il token endpoint**, non le API
Utente umano → OCI CLI con API key	OCI IAM user	API Key (static)	**Nessuno**	OCI User Principal	IAM Allow + IAM Deny + Network Sources	N/A	Landing Zone, Cloud Guard	Caso legacy, fuori dal modello ZTA moderno
App esterna → OCI APIs (OAuth2 client_credentials)	External IdP / Identity Domain	OAuth2 Confidential App	Network Perimeter vincolato alla Confidential App	OCI Service Principal	IAM Allow + IAM Deny + Network Sources	N/A	Security Zones, Cloud Guard	Network Perimeter **solo** per issuance token
M2M esterno → OCI APIs (JWT assertion / token exchange)	External workload	JWT → OCI Token Exchange	Network Perimeter sul token endpoint	OCI Service Principal	IAM Allow + IAM Deny + Network Sources	N/A	Security Zones, Cloud Guard	Token Exchange ≠ Network Source
Internet client → API Gateway → backend OCI	External user/app	OIDC/JWT su API Gateway	Identity Domain + Network Perimeter (solo se token OCI)	API Gateway principal	IAM per config + IAM Deny	WAF/NFW (N-S), NSG/SL, **ZPR (E-W)**	SZ, CG	Auth applicativa ≠ Auth OCI
On-prem M2M → API Gateway → Function Broker	External workload	OAuth2/JWT verso API GW	Network Perimeter se token OCI	Function Resource Principal	Dynamic Group + IAM Allow/Deny + Network Sources	ZPR + NSG/SL	SZ, CG	Broker isola l'identità esterna
Compute / OKE / Functions → OCI APIs	Nativa OCI	Resource Principal	**Nessuno**	Resource / Instance / Workload Principal	Dynamic Groups + IAM Allow/Deny + Network Sources	N/A	Landing Zone, CG	Nessun token endpoint pubblico
Compute / OKE / Functions → DB / workload interno	Nativa OCI	N/A	N/A	Resource Principal	N/A	**ZPR (ABAC)** + NSG/SL	SZ, CG	ZPR = sicurezza east-west
Compute / OKE / Functions → OCI Service (Object Storage, Logging) via PSA	Nativa OCI	Resource Principal	N/A	Resource Principal	IAM Allow/Deny + Network Sources	**PSA + ZPR/NSG**	SZ, CG	PSA = porta privata per servizi
Compute / OKE / Functions → OCI Service via SGW (no PSA)	Nativa OCI	Resource Principal	N/A	Resource Principal	IAM Allow/Deny + Network Sources	SGW + NSG/SL	CG	Meno granulare di PSA
App esterna → OCI Service (Object Storage)	External	API Key / PAR	Nessuno	User / PAR	IAM Allow/Deny	Public endpoint	CG	Fuori da ZTA consigliato

OCI Zero Trust Architecture: A Multi-Plane Enforcement Ontology

Within the Oracle Cloud Infrastructure Zero Trust model, it is essential to formally and unambiguously distinguish controls that operate prior to credential issuance from those that operate after issuance, as well as to separate external authentication mechanisms from native OCI authorization mechanisms.

The Network Perimeter is an exclusively pre-token control and is never directly associated with IAM policies, OCI resources, or Network Sources. Its proper scope is the Identity Domain, and its natural enforcement point is within Confidential Applications and user authentication flows that lead to OAuth2 or OpenID Connect (OIDC) token issuance. In other words, the Network Perimeter determines whether a token may be issued, not whether an already existing token may be used.

When an external application, a machine-to-machine (M2M) workload, or a user leverages OAuth2 flows—such as client credentials or JWT assertion—through a Confidential Application, the Network Perimeter constrains access to the token endpoint itself, preventing valid tokens from being issued from non-approved network contexts. If a token request originates from an unauthorized network, the flow is terminated before any OCI-consumable identity exists. This applies equally to interactive users and external workloads and represents the first true Zero Trust perimeter, as it prevents the existence of a valid credential outside its intended context.

Once the token has been issued and enters the OCI domain, the Network Perimeter no longer plays any role. From that moment forward, all authorization decisions fall exclusively within the OCI IAM control plane. At this stage, IAM Allow Policies, IAM Deny Policies, and Network Sources become authoritative. Network Sources do not block authentication nor prevent token issuance; rather, they condition the use of the token during invocation of OCI APIs. They are evaluated as IAM policy conditions and always operate post-token, verifying the network origin of an already authenticated request directed toward OCI infrastructure or service APIs.

This distinction is fundamental: Network Perimeter and Network Sources are neither alternative nor overlapping controls. They operate across different temporal and semantic layers. The former protects the token endpoint and federated authentication phase; the latter governs the use of a token within the OCI domain. Confusing the two undermines the integrity of the Zero Trust model.

With respect to native OCI principals—such as Resource Principals, Instance Principals, and OKE Workload Identity—there is no externally exposed token issuance phase. In these cases, identity is native, internal, and attested by the platform itself. Consequently, no Network Perimeter applies, as there is no public token endpoint to protect. Authorization is enforced through Dynamic Groups and IAM policies, while Network Sources may still be relevant to condition API usage if required. This represents the correct model for internal OCI workloads invoking OCI resources without static credentials.

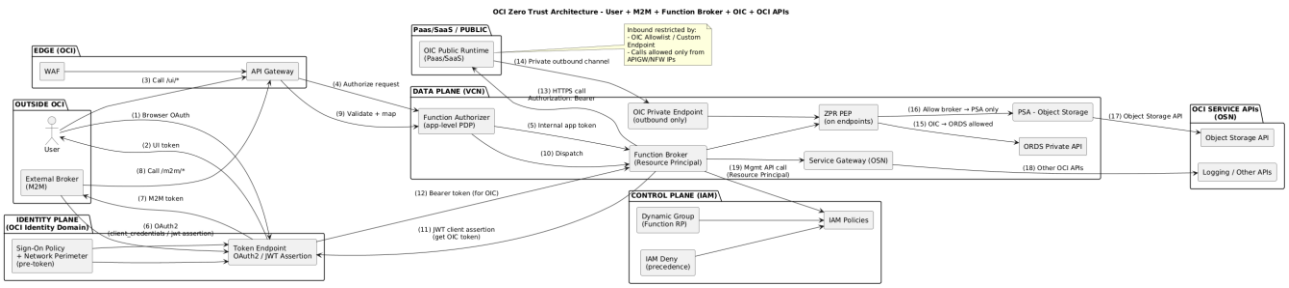
API keys represent a distinct and deliberately less secure case. When used from outside OCI, they bypass the modern token issuance model and cannot benefit from Network Perimeter protections or advanced OAuth2 mechanisms. In such scenarios, protection is limited to Network Sources, IAM Deny Policies, and potentially external controls such as API Gateway or application-level brokers. For this reason, OCI architectural guidance promotes OAuth2, Confidential Applications, and token exchange patterns, relegating API keys to legacy or transitional use cases.

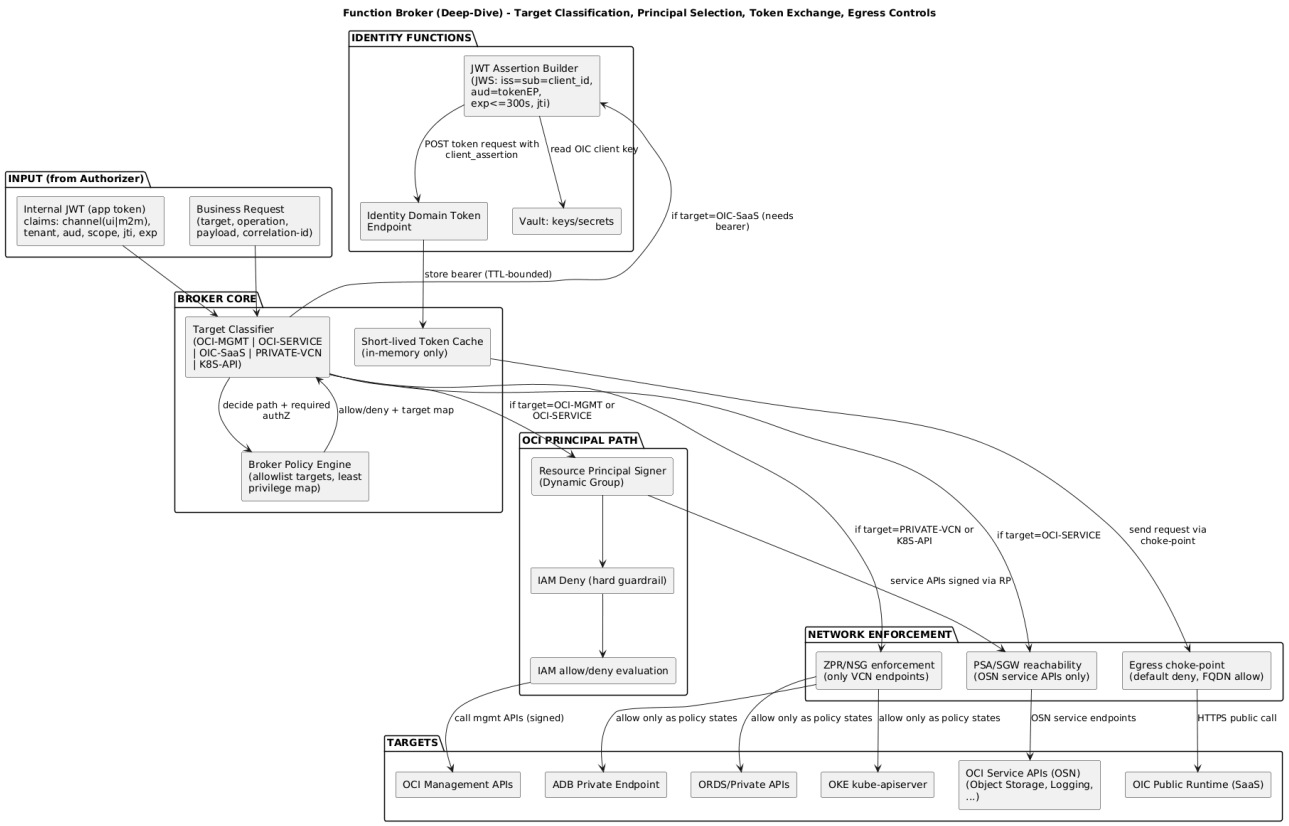
A specific case is the OCI CLI configured with browser-based authentication, which leverages an interactive OAuth2 flow. In this scenario, the token is issued by an Identity Domain through a

Confidential Application, and therefore the Network Perimeter is applicable and relevant. This reinforces the governing principle: whenever a token endpoint exists, the Network Perimeter is the first guardian; whenever an OCI API is invoked, Network Sources and IAM policies constitute the second layer of control.

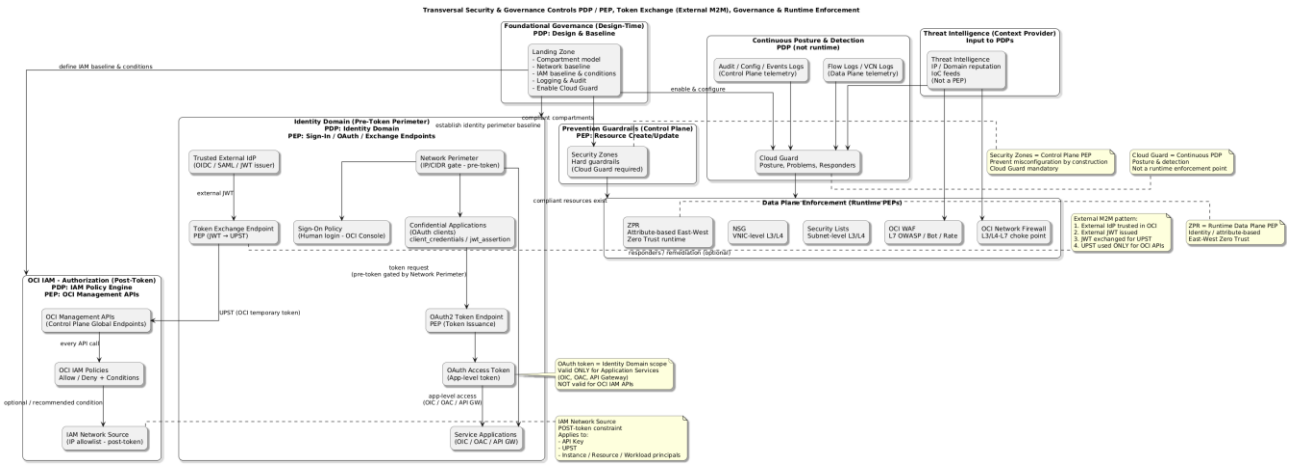
In summary, the correct architectural model is as follows: the Network Perimeter is always associated with Confidential Applications and OAuth2 or federated authentication flows and is the only control that determines whether a credential may be created; Network Sources are always associated with IAM policies and determine whether an existing credential may be used against OCI APIs; native OCI principals never traverse the Network Perimeter because no externally exposed token issuance phase exists; API keys do not fully participate in the Zero Trust model and must be treated as exceptions governed through deny-first strategies and compensating controls.

OCI Zero Trust Architecture: Scenario Function Broker and oci services





OCI Zero Trust Architecture: Scenario Token Exchange and oci services



OCI Zero Trust Architecture: Scenario Function Broker and oci services

The correct “Enterprise OCI Zero Trust Architecture (ZTA)” pattern for mixed User and Machine-to-Machine (M2M) scenarios is based on a pair of clearly separated components: the **Function Authorizer** and the **Function Broker**.

The **Function Authorizer** operates as an application-level Policy Decision Point (PDP), positioned at the edge or edge-adjacent layer. Its responsibility is the strong validation of external tokens, including interactive OIDC tokens (UI), M2M OAuth2 flows (client credentials or JWT assertion), and token exchanges originating from external Identity Providers. It enforces channel-level policies such as audience validation, scope constraints, tenant binding, token lifetime (TTL), anti-replay protection, and token class segregation. Upon successful validation, it issues an **Internal Access Token**—an application-level JWT signed with a key securely stored in OCI Vault—intended exclusively for downstream private services (Functions, microservices, ORDS, internal proxies).

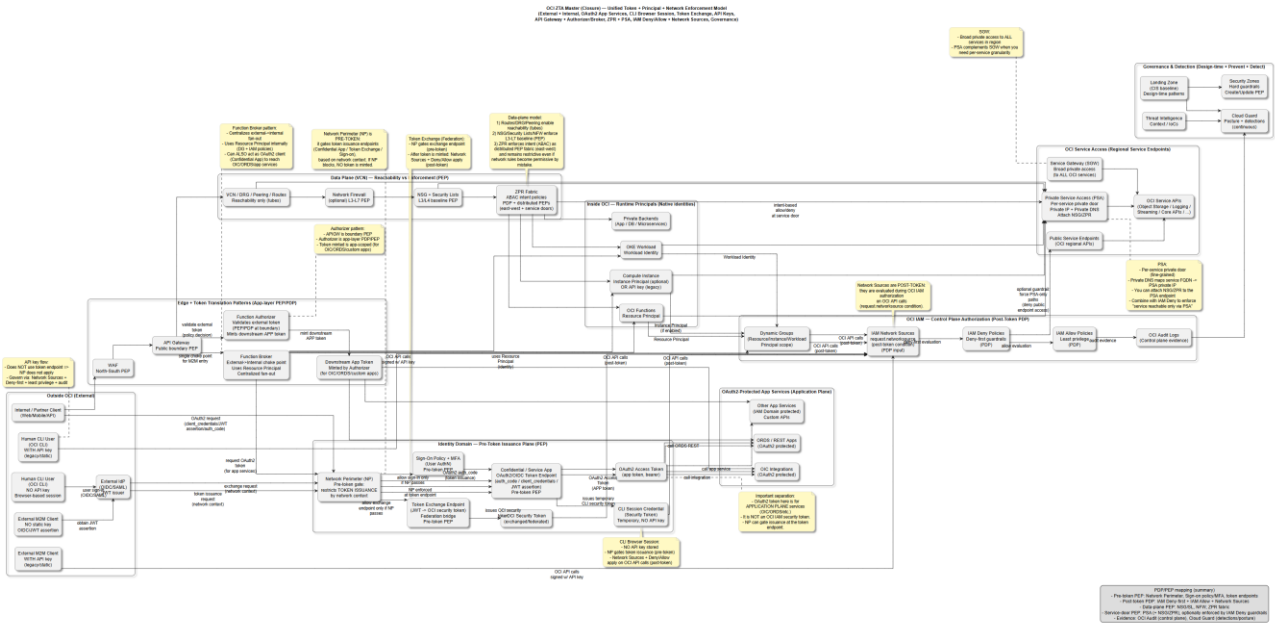
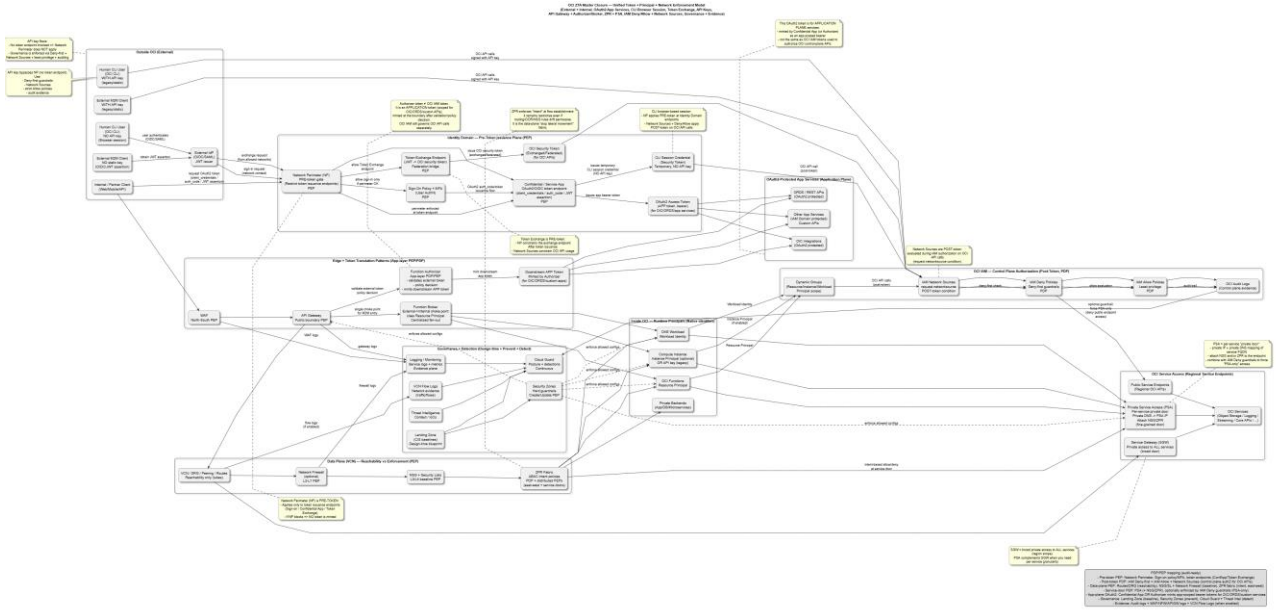
This Internal Token is not an OCI token and must never be accepted by OCI API Gateway nor used against public endpoints. Its purpose is semantic isolation of channels (UI versus M2M) and the prevention of impersonation and token relay attacks.

The **Function Broker** acts as a deterministic “dual-principal” executor. For invocations toward OCI services (Control Plane or OCI Service APIs), it uses exclusively a Resource Principal associated with a Dynamic Group and governed by IAM Allow/Deny policies. For invocations toward external SaaS or public application runtimes (for example, OIC public runtime), it uses exclusively OAuth2 Bearer tokens obtained through JWT client assertion against the OCI Identity Domain.

The Broker implements a deterministic router based on a defined “Target Class” model:

- **Target = OCI Management API:** Requests are signed with Resource Principal credentials and evaluated through IAM policy logic, including Deny precedence and conditional statements.
- **Target = OCI Service API:** Private reachability is enforced via Private Service Access (PSA) or Service Gateway (SGW), combined with runtime enforcement through ZPR and NSGs, and service-level IAM authorization.
- **Target = OIC public runtime:** Token issuance is performed through JWT client assertion; egress is routed through controlled choke points (such as OCI Network Firewall with FQDN allowlisting), and inbound access to OIC is restricted via allowlists or custom endpoints.
- **Target = Private workload (ORDS, OKE, Autonomous Database):** East–west segmentation is enforced through ZPR at the VCN level; application-level authentication is handled via mTLS or internal JWT for ORDS/microservices, OKE RBAC and TokenRequest mechanisms for Kubernetes, or database-native authentication for ADB.

In parallel, the architecture includes “outside-OCI CLI” operational flows without reliance on static API keys. Operators authenticate via browser-based sign-in and obtain a security token or session token (SSO/OAuth) issued by the Identity Domain for CLI or SDK usage. Control Plane calls are governed by IAM Allow/Deny policies and restricted by Network Sources tied to approved corporate IP ranges, with mandatory audit logging enabled. API keys are relegated to legacy status and must be formally confined through Network Sources, Deny guardrails, and SOC monitoring until complete migration to temporary token-based authentication is achieved.

The resulting Zero Trust property derives from the compositional layering of controls: pre-token controls (Sign-On Policies and Network Perimeter), deny-first enforcement (IAM Deny precedence), authorization (IAM Allow and conditions), runtime enforcement (ZPR, NSG, Network Firewall), service-specific authorization (OIC OAuth, ORDS application authentication, OKE RBAC, database authentication), and continuous detection and response (Audit Logs, logging pipelines, Cloud Guard, and Events).

OCI Zero Trust Architecture: Inbound and Outbound Process Scenarios Across OCI Boundaries